



LA TASSONOMIA CYBER DELL'ACN

*Definizione della tassonomia cyber dell'Agenzia
per la cybersicurezza nazionale*





TLP:CLEAR

Il presente documento ha un livello di condivisione **TLP:CLEAR**. Le informazioni possono essere distribuite senza restrizioni rispettando eventuali disposizioni sul copyright. Ulteriori dettagli sono disponibili sulla [pagina](#) dedicata del CSIRT Italia e sulla [pagina](#) dedicata del FIRST.

AGENZIA PER LA CYBERSICUREZZA NAZIONALE



L'Agenzia per la cybersicurezza nazionale (ACN) è stata istituita dal Decreto-legge n. 82 del 14 giugno 2021 che ha ridefinito l'architettura nazionale di cybersicurezza, con l'obiettivo di razionalizzare e semplificare il sistema di competenze esistenti a livello nazionale, anche attuando il coordinamento tra i soggetti pubblici coinvolti in materia di cybersicurezza, promuovendone azioni comuni.

L'Agenzia ha il compito di tutelare la sicurezza e la resilienza nello spazio cibernetico del Paese.

Siti web: [Agenzia per la Cybersicurezza Nazionale](#) [CSIRT Italia](#)

Contatti: info@acn.gov.it

Seguici sui nostri canali social:





Versione	Data	Descrizione delle modifiche
1.0	Novembre 2024	Prima emissione.
2.0	Novembre 2025	Principali modifiche: ampliamento del predicato "Involved Asset" e predisposizione della Tassonomia in formato JSON.

Esclusione di responsabilità

Il presente documento fornisce, a titolo esemplificativo e non esaustivo, indicazioni di mero ausilio alle attività di sicurezza dell'Organizzazione e non solleva la stessa dall'onere di porre in essere, nel rispetto della normativa vigente in materia di cybersicurezza, tutte le azioni ritenute necessarie per la prevenzione e mitigazione del rischio nonché la risoluzione degli impatti derivanti dal verificarsi di eventi e incidenti informatici.

SOMMARIO

EXECUTIVE SUMMARY	5
INTRODUZIONE	6
RIFERIMENTI	8
2.1 TASSONOMIE CYBER.....	8
LA TASSONOMIA DEGLI EVENTI CYBER DI ACN	11
3.1 BASELINE CHARACTERIZATION (BC).....	13
3.2 THREAT TYPE (TT)	18
3.3 THREAT ACTOR (TA).....	33
3.4 ADDITIONAL CONTEXT (AC)	36
APPENDICE	63

EXECUTIVE SUMMARY

La presente guida operativa definisce la “**Tassonomia Cyber dell’Agenzia per la Cybersicurezza Nazionale**” (**TC-ACN**), ossia il **linguaggio comune** per lo scambio delle informazioni relative a eventi e minacce di cybersicurezza.

Nello specifico, la TC-ACN ha lo scopo di fornire ai soggetti interessati gli strumenti per **caratterizzare un evento cyber** attraverso 219 attributi, per specificarne la natura e fornirne una descrizione granulare durante gli scambi informativi.

Al fine di massimizzarne la diffusione e facilitarne l’adozione, la presente Tassonomia viene fornita anche in formato **JSON**, consultabile al seguente [link](#).

INTRODUZIONE

1

Lo sviluppo tecnologico al quale si è assistito negli ultimi anni ha determinato la comparsa e l'evoluzione di rischi e minacce informatiche a danno dell'ecosistema cyber nazionale, così come esso è stato definito da documenti di policy dell'Agenzia quali le Relazioni Annuali e la Strategia Nazionale di Cybersicurezza 2022-2026, che persegue a livello strategico tre obiettivi brevemente descritti di seguito:

- **protezione degli asset strategici nazionali** attraverso un approccio sistemico orientato alla gestione e mitigazione del rischio, formato sia da un quadro normativo che da misure, strumenti e controlli che possono abilitare una transizione digitale resiliente del Paese;
- **risposta alle minacce, agli incidenti e alle crisi cyber nazionali** attraverso l'impiego di elevate capacità nazionali di monitoraggio, rilevamento, analisi e risposta e l'attivazione di processi che coinvolgano tutti gli attori facenti parte dell'ecosistema di cybersicurezza nazionale;
- **sviluppo consapevole e sicuro** delle tecnologie digitali, della ricerca e della competitività industriale, in grado di rispondere alle esigenze del mercato, funzione di cui l'ACN è responsabile, affrontando in maniera concreta i costanti cambiamenti del contesto cibernetico.

In linea con questi obiettivi, l'Agenzia si propone di condividere informazioni, conoscenze e analisi su rischi, minacce e incidenti informatici in maniera bidirezionale con il settore pubblico e privato, sviluppando le competenze e supportando la Pubblica Amministrazione e i settori produttivi nazionali nell'adattarsi a un panorama cyber in costante evoluzione.

In tale ottica l'Agenzia, attraverso la redazione della presente Guida Operativa, si prefigge di definire una "tassonomia" che sia in grado di:

- **agevolare lo scambio di informazioni** a livello nazionale attraverso l'adozione di un lessico comune che rappresenti una base metodologica per la condivisione di informazioni riguardo agli eventi cyber;
- **identificare, definire e caratterizzare** gli eventi cyber attraverso un'unica tassonomia rilevante a livello nazionale;



- fornire ai soggetti interessati un documento che si **armonizzi con le tassonomie internazionali** in materia di cybersecurity e che sia al contempo **adeguato al contesto normativo nazionale**.

Il prosieguo del documento è strutturato come segue:

- **Capitolo 2 – Riferimenti**, in cui si forniscono i principali riferimenti ad altre tassonomie cyber prese in considerazione nella definizione della tassonomia cyber.
- **Capitolo 3 – La tassonomia degli eventi cyber dell'ACN**, in cui si riporta la tassonomia degli eventi cyber costituita da un insieme di attributi che li caratterizzano.

In appendice si riporta in forma grafica di sintesi la Tassonomia Cyber dell'ACN.

In questo capitolo si riportano i principali framework in tema di tassonomie cyber sviluppati da gruppi di lavoro internazionali.

2.1 TASSONOMIE CYBER

Le fonti prese in esame includono documenti prodotti da gruppi di lavoro internazionali che si sono dedicati alla razionalizzazione di termini e concetti inerenti alla sicurezza cibernetica. In particolare, sono state analizzate le produzioni sul tema di:

- ENISA e Trusted Introducer;
- MITRE Corporation;
- Unione Europea e NATO.

Di seguito si riporta una breve descrizione delle tassonomie prodotte dalle citate fonti:

ENISA e Trusted Introducer

Istituita nel 2004, ENISA è l'Agenzia dell'Unione Europea per la cybersicurezza, incaricata di creare le condizioni per un elevato livello comune di cybersicurezza in tutta Europa. Nel 2018 l'ENISA ha avviato il **Reference Security Incident Taxonomy Working Group** (RSIT WG), con lo scopo di lavorare alla definizione di una tassonomia unica per supportare gli CSIRT europei nel trattare di incidenti di cybersicurezza¹. Il risultato è la "**Reference Incident Classification Taxonomy**"², che prende come riferimento la "Incident Classification / Incident Taxonomy according to eCSIRT.net" pubblicata nel 2012 da Trusted Introducer Service (anche noto come TI) e successivamente aggiornata nel 2015 sulla base della tassonomia degli incidenti elaborata dall'European CSIRT Network (eCSIRT).

¹ [Reference Security Incident Taxonomy Working Group – ENISA, 2018](#)

² [Reference Incident Classification Taxonomy – ENISA, 2018](#)

La tassonomia così recepita da ENISA classifica gli incidenti in 11 categorie con 32 relativi “esempi di incidenti”. Le categorie offerte da questa tassonomia sono generali e facilmente adattabili, per questo motivo sono state incluse nella TC-ACN (ad esempio Abusive content, Availability, Fraud, Information Gathering, etc). Tuttavia, prese separatamente, le tassonomie di ENISA e di Trusted Introducer non forniscono un livello di granularità sufficiente che è invece stato colmato con l’elaborazione della TC-ACN.

MITRE Corporation

La **MITRE Corporation** è un’organizzazione no-profit fondata nel 1958 allo scopo di guidare lo sviluppo di progetti che innalzino il livello generale di sicurezza in differenti aree di applicazione. Tra queste, MITRE si occupa di organizzare e creare team dedicati alla progettazione, sviluppo e supporto di soluzioni innovative nel campo della sicurezza informatica.

Il **MITRE ATT&CK** rappresenta un framework che fornisce una conoscenza dettagliata delle tattiche e delle tecniche utilizzate dagli avversari nel cyberspazio. Il progetto si compone di tre matrici di tattiche distinte per i domini Enterprise, Mobile e Industrial Control Systems (ICS), all’interno dei quali vengono definite le tecniche e le sotto tecniche associate all’attacco.

Le matrici del MITRE ATT&CK sono state opportunamente considerate e integrate dove necessario nella TC-ACN vista l’efficace granularità delle informazioni fornite. Tuttavia, la tassonomia del MITRE da sola non è stata ritenuta adatta a caratterizzare eventi e incidenti, data la sua specializzazione sull’analisi del comportamento degli attaccanti, le fasi di un attacco e gli strumenti da essi utilizzati.

Unione Europea e NATO

Nel 2011, l’Unione Europea e la NATO hanno avviato il **MISP Project**, un progetto con lo scopo di progettare, sviluppare, supportare e fornire strumenti open source per incentivare e permettere la condivisione delle informazioni di natura cyber.

Il MISP Project include innumerevoli iniziative, inclusa la “**MISP Taxonomies**”³, che ha lo scopo di fornire un insieme predefinito di linguaggi, standard e modelli di classificazione delle minacce informatiche che consentano lo scambio di informazioni in maniera efficace, efficiente e di valore tra più dispositivi in formato machine-readable. Tra questi, il “MISP Taxonomies” raccoglie anche le tassonomie elaborate da ENISA e dall’European CSIRT Network (eCSIRT), come analizzate nei paragrafi precedenti. Per questo motivo, le tassonomie incluse nel progetto sono state valutate

³ [MISP Taxonomies – MISP, NA](#)



e integrate ove ritenuto opportuno all'interno della TC-ACN.

LA TASSONOMIA DEGLI EVENTI CYBER DI ACN

Il presente Capitolo definisce la **Tassonomia Cyber dell'Agenzia per la Cybersicurezza Nazionale (TC-ACN)**.

La TC-ACN è costituita da 219 "valori", ognuno appartenente a uno dei 21 "predicati", i quali sono organizzati in 4 "macrocategorie".

In particolare, si definisce:

- **macrocategoria**, un gruppo di predicati con caratteristiche affini;
- **predicato**, un lemma che ha lo scopo di raccogliere un sottoinsieme di valori in base alle loro proprietà e caratteristiche intrinseche;
- **valore**, ossia l'elemento granulare che specifica una determinata caratteristica di un evento cyber identificata dal predicato di riferimento.

All'interno di questa struttura, si segnala che **per il solo predicato "Involved Asset" (3.4.3)** sono stati definiti, a causa della numerosità dei valori, 19 sotto-predicati che permettono al lettore di identificare più rapidamente il valore di interesse.

In Figura 1 sono rappresentate le quattro macrocategorie.

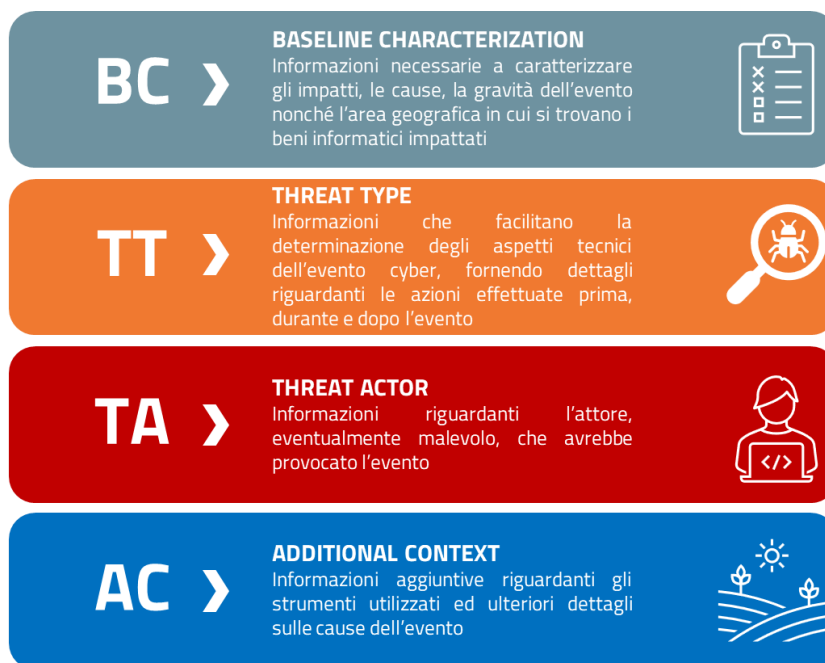


Figura 1: Struttura della tassonomia degli eventi cyber - Macrocategorie

In Figura 2 è invece riportata una rappresentazione della suddivisione dei predicati all'interno delle quattro macrocategorie.

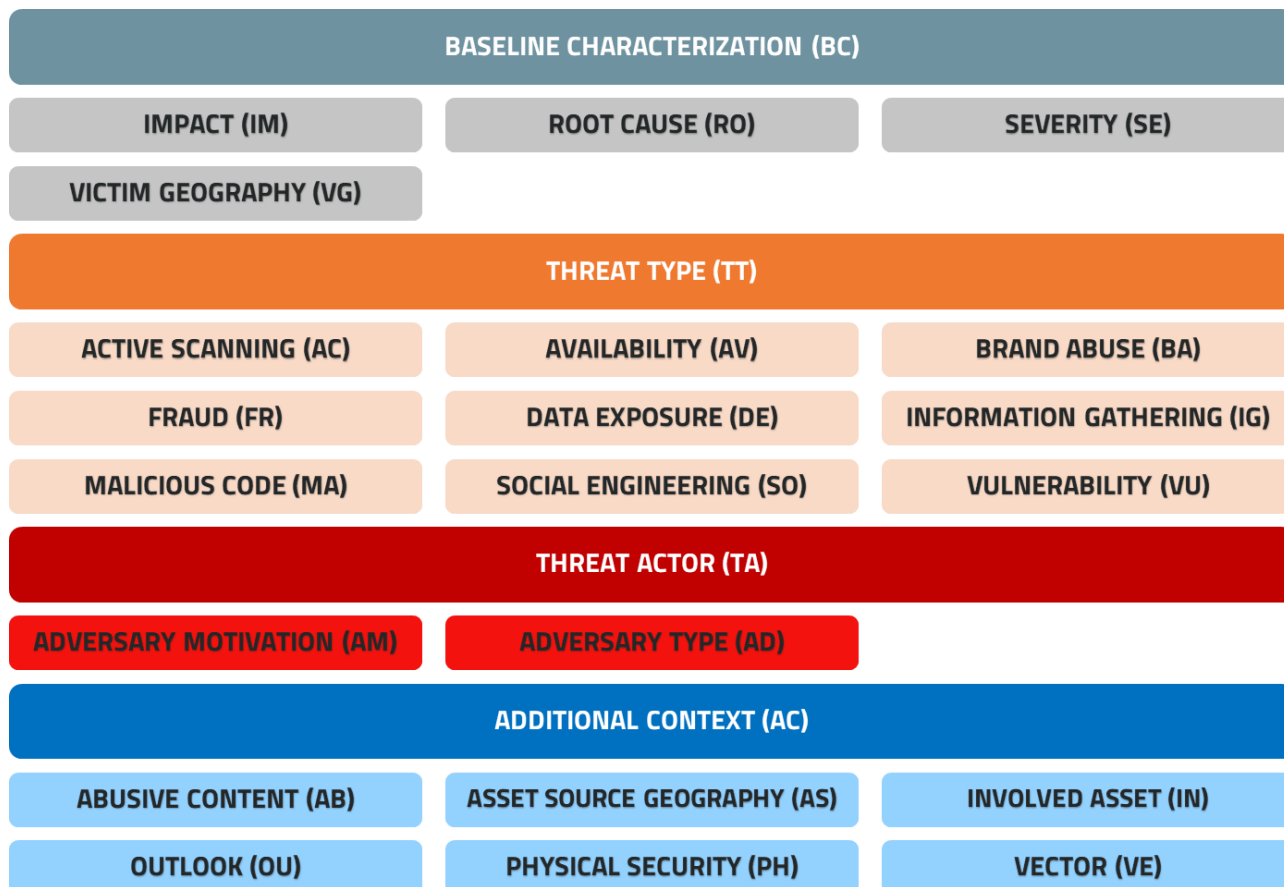


Figura 2: Struttura della tassonomia degli eventi cyber - Predicati

A titolo esemplificativo, consideriamo il caso di un *ransomware*, che è un malware. Pertanto, si avrà che il “**valore**” *ransomware* ricadrà nel **predicato “malicious code”**, il quale, a sua volta, sarà ricompreso nella **macrocategoria “Threat Type”**.

Nelle successive sezioni vengono dettagliati tutti i 219 valori, organizzati per predicati e macrocategorie. L’elenco completo della TC-ACN è riportato in APPENDICE .

3.1 BASELINE CHARACTERIZATION (BC)

3.1.1 Predicato: Impact (IM)

Il predicato **Impact** si riferisce alla perturbazione causata da un evento cyber.

I valori associati a **Impact** identificati dall’Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

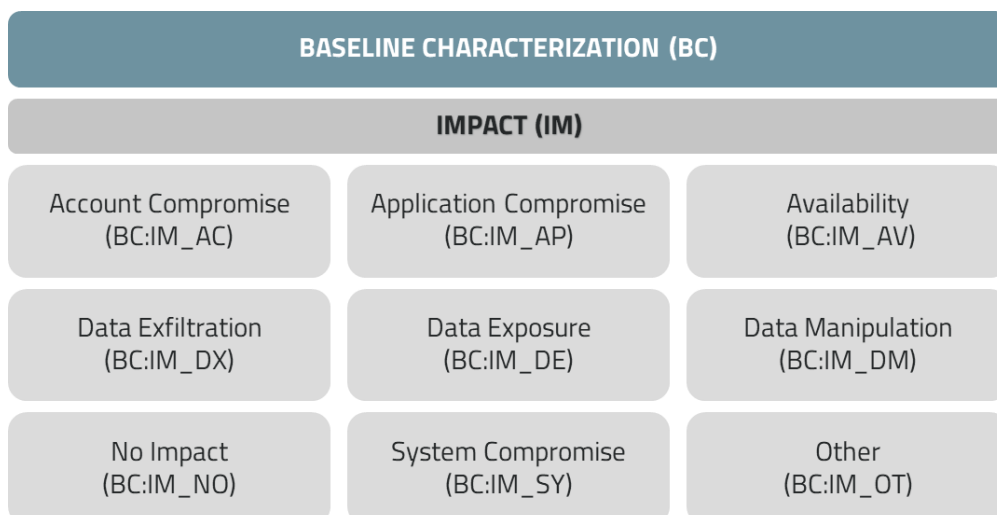


Figura 3: Predicato 'Impact' con i relativi valori

3.1.1.1 Account Compromise (BC:IM_AC)

Account Compromise identifica gli eventi cyber che hanno avuto come effetto la compromissione di un account utente o di servizio. È possibile specificare il tipo di account compromesso utilizzando il predicato Involved asset (§ 3.4.3).

3.1.1.2 Application Compromise (BC:IM_AP)

Application Compromise identifica gli eventi cyber che hanno avuto come effetto la compromissione di un’applicazione o di un servizio, incluse applicazioni Web, Mobile, Database, ecc. È possibile specificare il tipo di application compromise utilizzando il predicato Involved asset (§ 3.4.3).

3.1.1.3 Availability (BC:IM_AV)

Availability identifica gli eventi nei quali le attività malevole condotte da un attaccante hanno

causato effetti sulla disponibilità del sistema o servizio erogato. Nel caso in cui un evento cyber venga classificato utilizzando tale valore, dovrà essere esplicitato anche il predicato Availability (§ 3.2.2).

3.1.1.4 Data Exfiltration (BC:IM_DX)

Data Exfiltration identifica gli eventi cyber in cui è stata riscontrata la compromissione della riservatezza delle informazioni presenti su un bene informatico. Tale perdita o fuga dei dati può avvenire a causa di attività malevole, ad esempio a seguito di una compromissione di un file server, oppure accidentalmente, nel caso di un database esposto su Internet senza un accurato processo di autenticazione.

3.1.1.5 Data Exposure (BC:IM_DE)

Data Exposure si riferisce alla divulgazione non autorizzata di dati sensibili o riservati, causata da vulnerabilità di sicurezza, errori di configurazione o pratiche inadeguate di gestione delle informazioni. Questo fenomeno può portare alla diffusione di informazioni personali, finanziarie o aziendali aumentando il rischio di furti di identità, frodi o danni reputazionali per individui e organizzazioni.

3.1.1.6 Data Manipulation (BC:IM_DM)

Data Manipulation identifica gli eventi cyber in cui è stata riscontrata la compromissione dell'integrità delle informazioni presenti su un bene informatico. Tale valore include la modifica o la distruzione dei dati da parte di un attore malevolo.

3.1.1.7 No Impact (BC:IM_NO)

No Impact identifica un evento cyber che avrebbe potuto compromettere la disponibilità, l'autenticità, l'integrità o la riservatezza di dati conservati, trasmessi o elaborati o dei servizi offerti dai sistemi informatici e di rete o accessibili attraverso di essi, ma che è stato efficacemente evitato o non si è verificato. Un esempio è la ricezione di una e-mail di phishing riconosciuta come tale dall'utente e pertanto sostanzialmente priva di effetti.

3.1.1.8 System Compromise (BC:IM_SY)

System Compromise identifica gli eventi cyber che hanno avuto come effetto la compromissione di un bene informatico, ad esempio alterandone l'integrità.

3.1.1.9 Other (BC:IM_OT)

Other identifica gli eventi cyber relativi a Impact non identificabili con gli altri valori definiti nel sottoinsieme.

3.1.2 Predicato: Root Cause (RO)

Il predicato **Root Cause** categorizza le cause che hanno determinato uno specifico evento, sia di

natura accidentale, sia deliberata.

I valori associati a **Root Cause** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

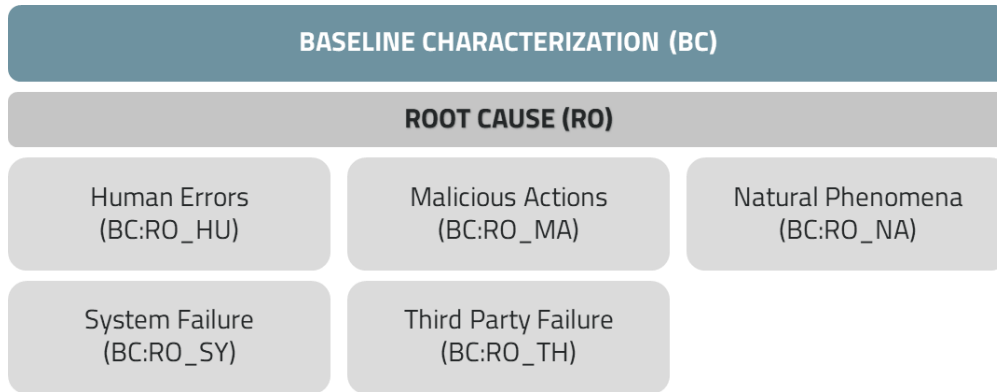


Figura 4: Predicato 'Root Cause' con i relativi valori

3.1.2.1 Human errors (BC:RO_HU)

Human Errors identifica gli eventi provocati da un errore umano non intenzionale. Un esempio è un'errata operazione che influisce sulla prevista funzionalità di un bene informatico.

3.1.2.2 Malicious Actions (BC:RO_MA)

Malicious Actions identifica qualsiasi tentativo di compromettere l'integrità, la confidenzialità o la disponibilità di un bene informatico.

3.1.2.3 Natural Phenomena (BC:RO_NA)

Natural Phenomena identifica gli eventi causati da un fenomeno naturale, come ad esempio, terremoti, valanghe ed esondazioni.

3.1.2.4 System Failure (BC:RO_SY)

System Failure identifica un evento non previsto, in cui un sistema cessa di funzionare secondo le specifiche progettuali previste, **comportando una perdita di servizio o una riduzione significativa della qualità del servizio fornito.**

3.1.2.5 Third Party Failure (BC:RO_TH)

Third Party Failure identifica l'interruzione o degradazione delle prestazioni di un sistema principale attribuibile a disfunzioni o guasti di servizi forniti da terze parti.

3.1.3 Predicato: Severity (SE)

Il predicato **Severity** ha lo scopo di indicare la gravità dell'impatto di un evento cyber. Questo predicato è associabile a quattro livelli, riferiti alla criticità dell'impatto subito.

I valori associati a **Severity** identificati dall'Agenzia per la tassonomia degli eventi cyber sono

elencati di seguito.

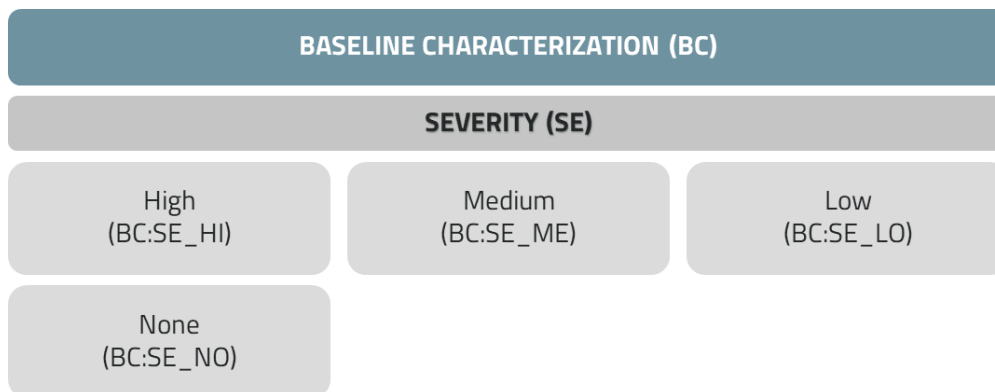


Figura 5: Predicato 'Severity' con i relativi valori

3.1.3.1 High (BC:SE_HI)

High identifica un evento cyber riferito ad una delle seguenti condizioni:

- l'organizzazione non è più in grado di fornire uno o più servizi essenziali agli utenti;
- dati/informazioni personali o proprietarie sono stati modificati, cancellati o esfiltrati;
- il ripristino dall'incidente non è possibile (ad esempio, dati sensibili esfiltrati e diffusi, non recuperabili a seguito di un evento ransomware).

3.1.3.2 Medium (BC:SE_ME)

Medium identifica un evento cyber riferito ad una delle seguenti condizioni:

- l'organizzazione è in grado di erogare un servizio essenziale solo ad una parte dell'utenza;
- è stato rilevato l'accesso e l'esfiltrazione a dati/informazioni personali o proprietarie;
- il ripristino è possibile con tempistiche non note in quanto, ad esempio, sono necessarie risorse aggiuntive o supporto esterno.

3.1.3.3 Low (BC:SE_LO)

Low identifica un evento cyber riferito ad una delle seguenti condizioni:

- l'organizzazione può ancora fornire tutti i servizi essenziali a tutti gli utenti, ma risultano non ottimali in termini di efficienza;
- è stato rilevato l'accesso a dati/informazioni sensibili o proprietarie;
- il ripristino è possibile con tempistiche note, anche tramite risorse aggiuntive.

3.1.3.4 None (BC:SE_NO)

None identifica un evento cyber riferito ad una delle seguenti condizioni:

- nessun effetto sulla capacità dell'organizzazione di erogare i servizi agli utenti;

- nessuna informazione è stata oggetto di accesso non autorizzato, esfiltrazione, modifica o cancellazione;
- il tempo necessario per il ripristino è prevedibile con le risorse esistenti.

3.1.4 Predicato: Victim Geography (VG)

Il predicato **Victim Geography** identifica l'area geografica in cui si trovano i beni informatici interessati dall'evento cyber.

I valori associati a **Victim Geography** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

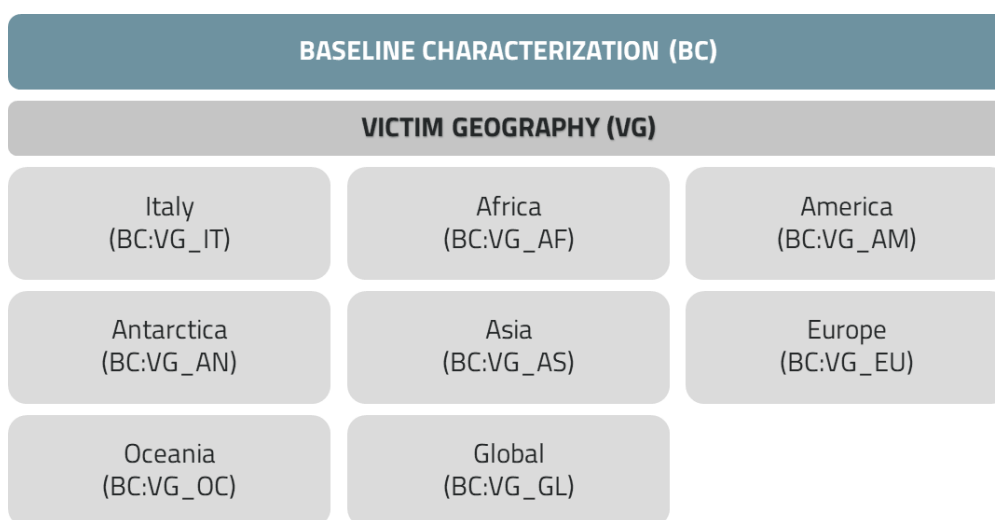


Figura 6: Predicato 'Victim Geography' con i relativi valori

3.1.4.1 Italy (BC:VG_IT)

Italy indica che l'evento cyber ha avuto un impatto su beni informatici localizzati in Italia.

3.1.4.2 Africa (BC:VG_AF)

Africa indica che l'evento cyber ha avuto un impatto su beni informatici localizzati geograficamente sul continente africano.

3.1.4.3 America (BC:VG_AM)

America indica che l'evento cyber ha avuto un impatto su beni informatici localizzati geograficamente sul continente americano.

3.1.4.4 Antarctica (BC:VG_AN)

Antarctica indica che l'evento cyber ha avuto un impatto su beni informatici localizzati geograficamente sul continente antartico.

3.1.4.5 Asia (BC:VG_AS)

Asia indica che l'evento cyber ha avuto un impatto su beni informatici localizzati geograficamente

sul continente asiatico.

3.1.4.6 Europe (BC:VG_EU)

Europe indica che l'evento cyber ha avuto un impatto su beni informatici localizzati geograficamente sul continente europeo.

3.1.4.7 Oceania (BC:VG_OC)

Oceania indica che l'evento cyber ha avuto un impatto su beni informatici localizzati nella zona continentale Oceania.

3.1.4.8 Global (BC:VG_GL)

Global indica che l'evento cyber ha avuto un impatto su beni informatici distribuiti in più paesi o ha un potenziale impatto globale.

3.2 THREAT TYPE (TT)

3.2.1 Predicato: Active Scanning (AC)

Il predicato **Active Scanning** identifica tecniche utilizzate da attori malevoli che prevedono la scansione della rete attraverso un contatto diretto con il sistema o con la rete target. Gli attori malevoli effettuano scansioni attive per diverse finalità, come per esempio l'analisi e la rilevazione di vulnerabilità e falle di sicurezza o per l'enumerazione delle risorse disponibili all'interno di un sistema o di una rete.

I valori associati ad **Active Scanning** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

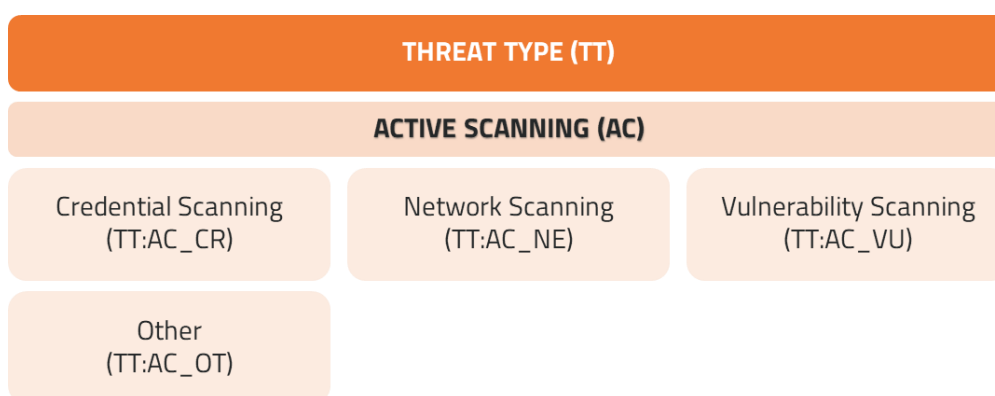


Figura 7: Predicato 'Active Scanning' con i relativi valori

3.2.1.1 Credential Scanning (TT:AC_CR)

Credential Scanning identifica gli eventi cyber in cui un attore malevolo effettua una scansione attiva per rilevare credenziali di autenticazione deboli, impropriamente configurate oppure esposte su un bene informatico. Questo tipo di attività include diverse tipologie di eventi, quali gli

attacchi a forza bruta, volti a individuare la password di uno o più account specifici, oppure attacchi di account discovery, mirati alla scoperta di account validi o realmente esistenti sul sistema target.

3.2.1.2 Network Scanning (TT:AC_NE)

Network Scanning identifica gli eventi cyber in cui un attore malevolo utilizza tecniche e procedure mirate a identificare la presenza di servizi in esecuzione su beni informatici remoti o connessi all'infrastruttura target. Questa categoria di evento comprende la scansione delle porte (port scan), la mappatura della rete (network mapping) e la rilevazione del sistema operativo (OS fingerprinting).

3.2.1.3 Vulnerability Scanning (TT:AC_VU)

Vulnerability Scanning identifica gli eventi cyber in cui un attore malevolo utilizza tecniche e procedure mirate in modo specifico all'individuazione di vulnerabilità presenti in un bene informatico al fine di mappare la superficie d'attacco.

3.2.1.4 Other (TT:AC_OT)

Other identifica gli eventi cyber relativi ad Active Scanning non identificabili con gli altri valori definiti nel sottoinsieme.

3.2.2 Predicato: Availability (AV)

In ambito informatico, per **Availability** (Disponibilità) si intende la capacità di un sistema informativo di garantire agli utenti autorizzati un accesso e un uso tempestivo e sempre fruibile delle informazioni. Tale predicato è in uso per specificare la causa dell'impatto sulla disponibilità.

I valori associati a **Availability** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

THREAT TYPE (TT)		
AVAILABILITY (AV)		
Data encryption (TT:AV_DA)	DDoS (TT:AV_DD)	DoS (TT:AV_DO)
Misconfiguration (TT:AV_MI)	Outage (TT:AV_OU)	Other (TT:AV_OT)

Figura 8: Predicato 'Availability' con i relativi valori

3.2.2.1 Data Encryption (TT:AV_DA)

Data Encryption identifica gli eventi cyber in cui un attore malevolo applica algoritmi di cifratura

ai dati custoditi in un sistema informatico compromesso, senza il consenso del proprietario, al fine di renderli inaccessibili. Tale attività comporta principalmente un impatto sulla disponibilità dei dati presenti sul bene informatico e sull'erogazione dei servizi. Un esempio di tale evento è la cifratura dei dati di un sistema informatico a seguito dell'esecuzione di un ransomware.

3.2.2.2 DDoS (TT:AV_DD)

Distributed Denial of Service (DDoS) identifica gli eventi cyber in cui un attore malevolo effettua un attacco, da sorgenti multiple e distribuite, che mira a compromettere la disponibilità di un bene informatico o un di servizio mediante esaurimento delle sue risorse di rete, di elaborazione o di memoria.

3.2.2.3 DoS (TT:AV_DO)

Denial of Service (DoS) identifica gli eventi cyber in cui un attore malevolo effettua un attacco che mira a compromettere la disponibilità di un bene informatico o di un servizio mediante esaurimento delle sue risorse di rete, di elaborazione o di memoria.

3.2.2.4 Misconfiguration (TT:AV_MI)

Misconfiguration identifica gli eventi cyber non malevoli in cui una configurazione errata o non ottimale di un bene informatico o di una sua componente ha compromesso la disponibilità di un servizio. Un caso d'esempio è un'errata configurazione di un componente di rete che potrebbe causare la perdita totale o parziale di erogazione di un servizio. È importante evidenziare che la disponibilità è stata compromessa a causa di un'azione non intenzionale e quindi non malevola, pertanto, tale predicato è comunemente associato al valore Human errors (§ 3.1.2.1) del predicato Root cause (§ 3.1.2).

3.2.2.5 Outage (TT:AV_OU)

Outage identifica gli eventi cyber non malevoli in cui si è riscontrata la perdita totale o parziale della disponibilità di un bene informatico a causa di eventi naturali o causati dall'uomo. Possibili cause di un evento di indisponibilità possono essere l'avvenimento di un disastro naturale, il mancato funzionamento dei sistemi di refrigerazione di un datacenter oppure un guasto elettrico. È importante evidenziare che la disponibilità è stata compromessa a causa di un'azione non intenzionale e quindi non malevola.

3.2.2.6 Other (TT:AV_OT)

Other identifica gli eventi cyber nei quali si riscontra una perdita di disponibilità di un bene informatico o di un applicativo per una causa che non rientra in quelle indicate negli altri valori associabili al predicato Availability (§ 3.2.2).

3.2.3 Predicato: Brand Abuse (BA)



Un'azione o una serie di azioni intenzionali che sfruttano il valore o la reputazione di un marchio per scopi malevoli, phishing, cybersquatting, typosquatting. Il **Brand Abuse** può includere l'imitazione di siti web, l'uso non autorizzato di loghi o di marchi e la creazione di contenuti apparentamenti legittimi destinati a trarre in inganno gli utenti.

I valori associati per **Brand Abuse** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

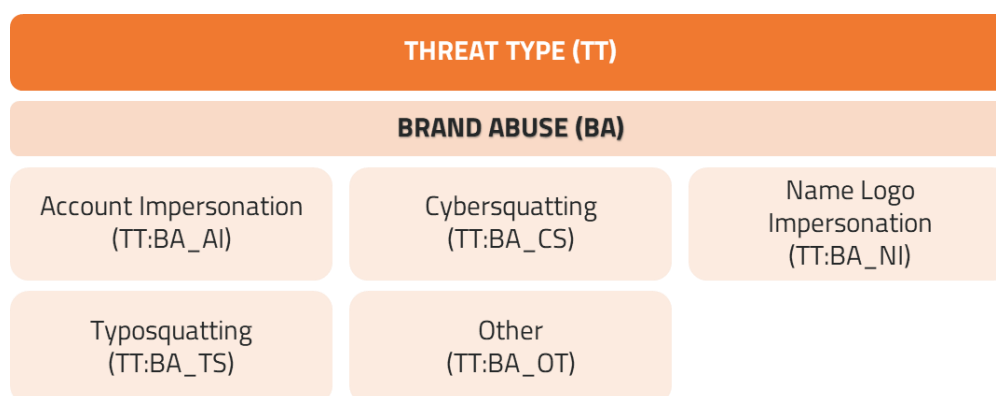


Figura 9: Predicato 'Brand Abuse' con i relativi valori

3.2.3.1 Account Impersonation (TT:BA_AI)

Account Impersonation si riferisce all'attività in cui un attore malevolo si finge un'altra persona, sistema o organizzazione per ingannare la vittima e ottenere l'accesso non autorizzato a informazioni sensibili. Questa attività può includere sia la compromissione di un account esistente, sia la creazione di un nuovo profilo affine.

3.2.3.2 Cybersquatting (TT:BA_CS)

Cybersquatting si riferisce alla pratica di registrare e utilizzare abusivamente un nome di dominio Internet identico o simile a marchi registrati, nomi di servizi, nomi personali o aziendali, con l'intento malevolo di deviare il traffico verso altri siti per ricavarne un profitto economico, diffondere malware o rubare proprietà intellettuale.

3.2.3.3 Name Logo Impersonation (TT:BA_NI)

Name Logo Impersonation si riferisce all'atto deliberato di replicare o imitare in modo fraudolento il nome e il logo di un'entità riconosciuta, come un'organizzazione rinomata o un servizio noto, nell'intento di trarre in inganno la vittima. Questa tecnica è impiegata prevalentemente nelle strategie di phishing o in altri schemi di ingegneria sociale.

3.2.3.4 Typosquatting (TT:BA_TS)

Typosquatting, conosciuto anche come "URL hijacking", è una pratica fraudolenta nell'ambito della sicurezza informatica che si verifica quando un attore malevolo registra deliberatamente nomi di dominio che imitano siti web esistenti con lievi variazioni ortografiche. Questo fenomeno

sfrutta gli errori di digitazione che gli utenti commettono durante la battitura degli indirizzi web nel browser. Questa pratica può essere utilizzata per una serie di attività fraudolente, tra cui deviare il traffico verso altri siti, phishing o la diffusione di malware.

3.2.3.5 Other (TT:BA_OT)

Other identifica gli eventi cyber relativi a Brand Abuse non identificabili con gli altri valori definiti nel sottoinsieme.

3.2.4 Predicato: Fraud (FR)

Il predicato **Fraud** identifica un'azione o una serie di azioni deliberatamente compiute con l'intento di ottenere un vantaggio economico o di altro tipo, attraverso l'inganno o la manipolazione.

I valori associati a **Fraud** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

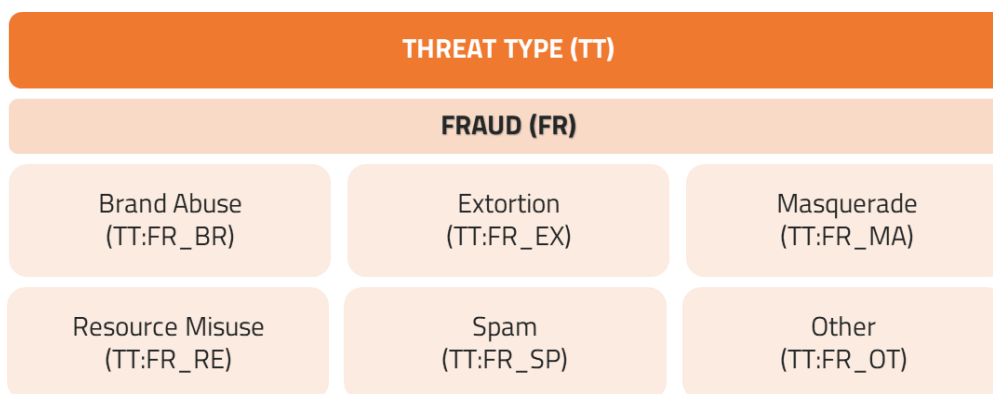


Figura 10: Predicato 'Fraud' con i relativi valori

3.2.4.1 Brand Abuse (TT:FR_BR)

Brand Abuse identifica un'attività fraudolenta in cui un attore malevolo sfrutta la notorietà di un'organizzazione per creare falsi siti web, false campagne pubblicitarie o false partnership con il proposito di danneggiarne la reputazione o di condurre attività di criminalità informatica. Tra gli esempi rientrano: la creazione di profili o gruppi falsi sui social media che sfruttano illecitamente il brand o il logo di un'azienda, la creazione di applicazioni mobili ingannevoli o la distribuzione di pubblicità non autorizzate.

3.2.4.2 Extortion (TT:FR_EX)

Extortion identifica, nel contesto della sicurezza informatica, l'attività criminale in cui un aggressore esercita coercizione su un individuo o un'organizzazione per ottenere benefici finanziari o altre forme di compensazione. La condotta viene attuata tramite l'esercizio della minaccia di causare danni o di divulgare informazioni sensibili. Un esempio di questa pratica è il

ransomware, un tipo di malware che cifra i dati della vittima rendendoli inaccessibili, utilizzato per costringere la vittima a pagare un riscatto, di solito in criptovalute, in cambio della chiave di decifratura. Altre forme di estorsione possono includere la minaccia di diffusione di dati personali o aziendali, qualora non vengano soddisfatte le richieste dell'aggressore.

3.2.4.3 Masquerade (TT:FR_MA)

Masquerade indica un'attività fraudolenta in cui un attore malevolo assume l'identità di un altro utente, dispositivo o entità all'interno di una rete o sistema informatico, al fine di eludere i meccanismi di sicurezza e acquisire accessi non autorizzati a risorse o beni informatici.

Tale attacco implica l'utilizzo fraudolento di credenziali, indirizzi di rete, token di autenticazione o altri dati identificativi utili per impersonare una fonte autorizzata fidata. Un tipico caso è rappresentato da un attaccante che invia un'e-mail a un dipendente aziendale fingendo di essere il CEO dell'azienda e richiede con urgenza un trasferimento di fondi per una transazione aziendale critica o la divulgazione di informazioni riservate, come dati finanziari o dati dei clienti.

3.2.4.4 Resource misuse (TT:FR_RE)

Resource Misuse identifica gli eventi cyber in cui un attore malevolo ha sfruttato in maniera non autorizzata le risorse di un computer o di una rete per scopi illeciti. Un tipico esempio è rappresentato da un dipendente che sfrutta il suo accesso ai sistemi aziendali per eseguire programmi che estraggono criptovalute (mining) oppure per effettuare attacchi informatici ai danni di soggetti terzi.

3.2.4.5 Spam (TT:FR_SP)

Spam identifica gli eventi cyber in cui un attore malevolo invia messaggi pubblicitari indesiderati o non richiesti, generalmente di carattere commerciale. I messaggi di spam possono essere inviati attraverso qualunque sistema di comunicazione, tra cui messaggi di posta elettronica, SMS, chat, forum e social media.

3.2.4.6 Other (TT:FR_OT)

Other identifica gli eventi cyber relativi al predicato Fraud non identificabili con gli altri valori definiti nel sottoinsieme.

3.2.5 Predicato: Data Exposure (DE)

Il predicato **Data Exposure** identifica gli eventi cyber in cui è occorsa una violazione di sicurezza dei dati/informazioni personali o proprietarie. L'evento si riferisce alla divulgazione involontaria o non autorizzata di dati sensibili, compromettendo la riservatezza e la sicurezza delle informazioni.

I valori associati a **Data Exposure** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

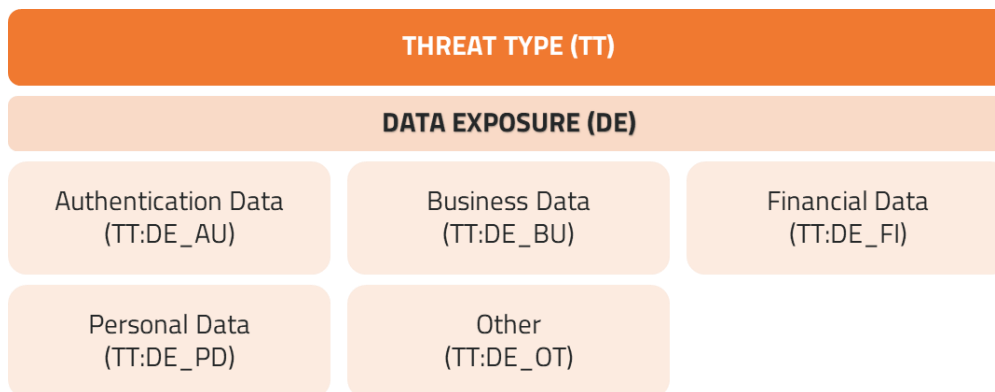


Figura 11: Predicato 'Data Exposure' con i relativi valori

3.2.5.1 Authentication Data (TT:DE_AU)

Authentication Data identifica gli eventi cyber nei quali è stata identificata una violazione di sicurezza dei dati relativi all'autenticazione degli utenti del bene informatico impattato, come username e password.

3.2.5.2 Business Data (TT:DE_BU)

Business Data identifica gli eventi cyber nei quali è stata identificata una violazione di sicurezza dei dati relativi all'azienda, quali dati sulle sue attività, sui suoi contratti, sulla proprietà intellettuale, ecc.

3.2.5.3 Financial Data (TT:DE_FI)

Financial Data identifica gli eventi cyber nei quali è stata identificata una violazione di sicurezza dei dati relativi alla sfera finanziaria dell'azienda, come entrate, uscite, dati di transazioni finanziarie, dati relativi a carte di credito, ecc.

3.2.5.4 Personal Data (TT:DE_PD)

Personal Data identifica gli eventi cyber nei quali si è verificata una violazione di sicurezza dei personali, ovvero delle informazioni che identificano o rendono identificabile, **direttamente o indirettamente**, una persona fisica e che possono fornire informazioni sulle sue caratteristiche, le sue abitudini, il suo stile di vita, le sue relazioni personali, il suo stato di salute, la sua situazione economica, ecc.

3.2.5.5 Other (TT:DE_OT)

Other identifica gli eventi cyber relativi a **Data Exposure** non identificabili con gli altri valori definiti nel sottoinsieme.

3.2.6 Predicato: Information Gathering (IG)

Per **Information Gathering** si intendono le tecniche, tattiche o procedure che possono essere utilizzate da criminali informatici al fine di raccogliere quante più informazioni possibili su un

determinato obiettivo, sia esso un utente, un'applicazione, un sistema o una rete.

I valori associati a **Information Gathering** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

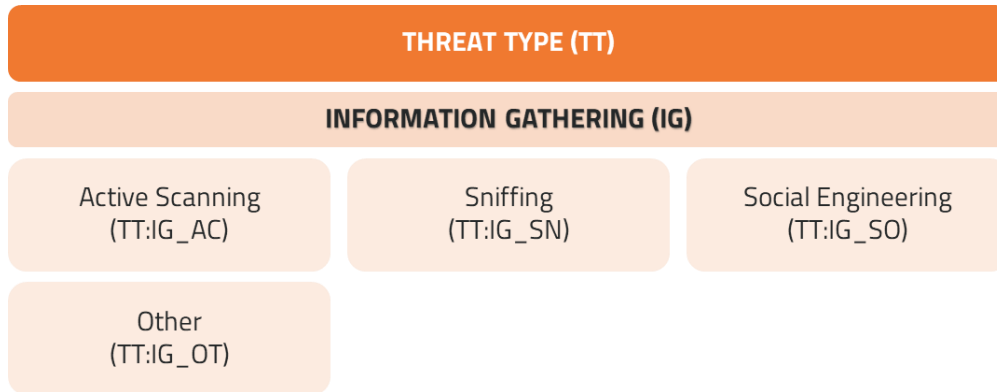


Figura 12: Predicato 'Information Gathering' con i relativi valori

3.2.6.1 Active Scanning (TT:IG_AC)

Active Scanning identifica gli eventi cyber in cui un attore malevolo cerca di raccogliere informazioni mediante una scansione attiva, ossia attraverso contatti diretti con il bene informatico target. Per specificare i dettagli sulla tipologia di scansione attiva si utilizza il predicato Active Scanning (§ 3.2.1).

3.2.6.2 Sniffing (TT:IG_SN)

Sniffing identifica gli eventi cyber in cui un attore non autorizzato utilizza tecniche o strumenti atti ad acquisire pacchetti di rete con il fine di rubare dati, monitorare attività di rete e raccogliere informazioni. Un esempio di eventi identificabili con tale valore è l'osservazione non autorizzata di informazioni d'interesse come ad esempio, header, credenziali o token di accesso non cifrati inviati in rete.

3.2.6.3 Social Engineering (TT:IG_SO)

Social engineering identifica gli eventi cyber in cui un attore malevolo utilizza un insieme di tecniche e tattiche per persuadere un individuo a compiere determinate azioni per diverse finalità, tra le quali si evidenziano le seguenti:

- ottenere informazioni personali;
- ottenere credenziali di accesso;
- indurre l'utente a compiere azioni come, ad esempio, installare malware.

Attività di social engineering fanno leva sulla componente psicologica ed emotiva della vittima per ottenere gli obiettivi prefissati.

3.2.6.4 Other (TT:IG_OT)

Other identifica gli eventi cyber relativi a Information Gathering non identificabili con gli altri valori definiti nel sottoinsieme.

3.2.7 Predicato: Malicious Code (MA)

Per **Malicious Code** si intende un software o una porzione di codice potenzialmente dannosa, spesso inquadrabile come malware, che, una volta eseguito su un sistema, ha l'obiettivo di prenderne il controllo e/o comprometterne potenzialmente la riservatezza, l'integrità e la disponibilità.

I valori associati a **Malicious Code** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

THREAT TYPE (TT)		
MALICIOUS CODE (MA)		
Backdoor (TT:MA_BA)	Banker (TT:MA_BK)	Bot (TT:MA_BO)
Coin Miner (TT:MA_CO)	Exploit Kit (TT:MA_EX)	Hacking Tool (TT:MA_HA)
Information Stealer (TT:MA_IN)	Loader (TT:MA_LO)	Potentially Unwanted Program (TT:MA_PO)
Ransomware (TT:MA_RA)	Remote Access Tool (TT:MA_RE)	Rootkit (TT:MA_RO)
Trojan (TT:MA_TR)	Virus (TT:MA_VI)	Webshell (TT:MA_WE)
Wiper (TT:MA_WI)	Worm (TT:MA_WO)	Unknown (TT:MA_UN)

Figura 13: Predicato 'Malicious Code' con i relativi valori

3.2.7.1 Backdoor (TT:MA_BA)

Una **Backdoor** è una tipologia di malware che garantisce un accesso secondario a un bene informatico compromesso, consentendo all'attaccante di accedervi da remoto ed eseguire azioni arbitrarie, come il trasferimento di file o l'esecuzione di comandi.



3.2.7.2 Banker (TT:MA_BK)

Un **Banker**, anche noto come banking trojan, è una tipologia di malware che tenta di sottrarre illecitamente le credenziali dei clienti di istituti bancari o di ottenere l'accesso alle loro informazioni finanziarie, tipicamente intercettando le comunicazioni del browser.

3.2.7.3 Bot (TT:MA_BO)

Un **Bot** è un programma informatico progettato per adempiere ad un preciso scopo, sia esso lecito o dannoso. In questo secondo caso, si parla di **bot malware**, ovvero strumenti utilizzati da criminali informatici per creare una rete di computer zombie, nota come *botnet*, ed effettuare un insieme di attività malevole di diversa natura. Spesso i bot vengono installati sulle macchine target a insaputa dell'utente.

3.2.7.4 Coin Miner (TT:MA_CO)

Un **Coin Miner** è una tipologia di malware che sfrutta la potenza di calcolo del bene informatico target per estrarre criptovalute a insaputa dell'utente.

3.2.7.5 Exploit Kit (TT:MA_EX)

Un **Exploit Kit** è un insieme di strumenti software progettati per sfruttare le vulnerabilità presenti in una rete, in un sistema o in un'applicazione. In sicurezza informatica, questi strumenti sono utilizzati dagli attaccanti per eseguire e automatizzare numerose tecniche e procedure di attacco al fine di accedere, infettare e danneggiare i beni informatici.

3.2.7.6 Hacking Tool (TT:MA_HA)

Un **Hacking Tool** è un programma progettato per violare le misure di sicurezza di un bene informatico. È utilizzato sia per attività di natura legittima (ad esempio per valutare la sicurezza di un bene informatico in un'attività di tipo red team) sia in contesti non autorizzati o per scopi illeciti. Alcuni esempi sono PsExec, Mimikatz, Cobalt Strike e LOIC.

3.2.7.7 Information Stealer (TT:MA_IN)

Un **Information Stealer**, o più brevemente infostealer, è una tipologia di malware che ha lo scopo di raccogliere informazioni su un bene informatico in maniera illegittima. Queste informazioni possono includere credenziali di accesso, dati personali e informazioni finanziarie. I malware noti come **keylogger** o **spyware** rientrano in questa classificazione.

3.2.7.8 Loader (TT:MA_LO)

Un **Loader** è una tipologia di malware che permette di scaricare ed eseguire malware aggiuntivi sul bene informatico compromesso. I malware noti come **dropper** e **downloader** rientrano in questa classificazione.



3.2.7.9 Potentially Unwanted Program (TT:MA_PO)

Un **Potentially Unwanted Program**, noto anche come PUP o PUA (Potentially Unwanted Application), può essere considerato come un software indesiderato secondo le preferenze dell'utente. Sebbene questa classificazione non indichi la presenza di un malware, i PUP possono rappresentare una minaccia per la privacy e la sicurezza del sistema e dell'utente.

3.2.7.10 Ransomware (TT:MA_RA)

Il **Ransomware** è una tipologia di minaccia che ha lo scopo di cifrare i dati del bene informatico target in modo da comprometterne la disponibilità e l'integrità. Inoltre, in questa tipologia di minaccia spesso l'attaccante crea dei file, detti *ransom notes*, tramite i quali viene richiesto alla vittima un riscatto in cambio dell'accesso ai propri dati. In alcuni casi i dati, prima di essere cifrati, vengono esfiltrati in modo da offrire all'attaccante uno strumento in più di ricatto nei confronti della vittima.

3.2.7.11 Remote Access Tool (TT:MA_RE)

Un **RAT**, acronimo di Remote Access Tool, è una tipologia di malware che consente all'attaccante di controllare un bene informatico target da remoto. Questa tipologia di codice malevolo permette di eseguire varie azioni non autorizzate, come l'acquisizione di dati, il trasferimento di file e l'esecuzione di comandi arbitrari.

3.2.7.12 Rootkit (TT:MA_RO)

Un **Rootkit** è una tipologia di malware tipicamente sofisticato progettato per infiltrarsi all'interno di un sistema operativo o di un'applicazione, mascherando la sua presenza e ottenendo privilegi di accesso elevati. Un rootkit ha la caratteristica di infettare e modificare le funzioni del sistema operativo e le sue strutture dati. In sicurezza informatica, le caratteristiche del rootkit permettono di evadere i controlli dell'antivirus e di garantire persistenza a lungo termine sul sistema target.

3.2.7.13 Trojan (TT:MA_TR)

Un **Trojan** è una tipologia di software che si presenta all'utente sotto forma di programma legittimo o comunque non dannoso, ma che una volta eseguito ha lo scopo di scaricare e avviare sul bene informatico target un ulteriore software malevolo. I trojan sono progettati per ingannare gli utenti e possono svolgere una vasta gamma di funzioni malevole, come il furto di informazioni, il controllo remoto del sistema, l'installazione di altri malware o la creazione di backdoor per consentire l'accesso non autorizzato.

3.2.7.14 Virus (TT:MA_VI)

Un **Virus** è un software potenzialmente dannoso che, quando eseguito su un bene informatico, ha l'obiettivo di autoreplicarsi modificando (infettando) i programmi in esecuzione e alterandone (injection) il funzionamento. Utilizzando un virus, un attaccante potrebbe eliminare i dati e/o i



programmi presenti su un bene informatico, bloccarne l'accesso o attuare tecniche di compromissione avanzate per garantirsi persistenza sul sistema e permetterne la raggiungibilità da remoto (i.e. installando una backdoor).

3.2.7.15 Webshell (TT:MA_WE)

Una **Webshell** è una tipologia di script o programma che viene installato su un server web compromesso al fine di ottenere un accesso non autorizzato e persistente sul bene informatico.

3.2.7.16 Wiper (TT:MA_WI)

Il **Wiper** è una tipologia di malware il cui obiettivo principale è quello di eliminare in modo irreversibile dati e file presenti su un bene informatico compromesso. A differenza di altri tipi di malware che cercano di rubare informazioni o estorcere denaro, il wiper ha come obiettivo principale l'eliminazione dei dati, spesso con l'intento di causare danni irreparabili o di sabotare le attività di un'organizzazione.

3.2.7.17 Worm (TT:MA_WO)

Il **Worm** è un software potenzialmente dannoso che l'attaccante può sfruttare per replicare un malware all'interno di un bene informatico per comprometterne le funzionalità. La caratteristica principale del worm è la capacità di autoreplicarsi su una rete, senza richiedere l'interazione diretta dell'utente. I worm, a differenza di altri tipi di malware come i virus, possono propagarsi in modo indipendente e autonomo, ad esempio sfruttando le vulnerabilità dei beni informatici o le funzionalità di condivisione di file e risorse di rete.

3.2.7.18 Unknown (TT:MA_UN)

Unknown identifica una tipologia di codice malevolo per cui non si hanno informazioni sufficienti a indicarne la natura. Tale valore si utilizza in eventi cyber in cui è stata riscontrata la l'esecuzione di codice malevolo o malware ma non è ancora in grado di stabilirne la tipologia.

3.2.8 Predicato: Social Engineering (SO)

Il predicato **Social Engineering** identifica un evento di sicurezza informatica in cui un attore malevolo sfrutta un insieme di tecniche e tattiche per persuadere un individuo a compiere azioni che hanno conseguenze sul dominio cyber quali, ad esempio, il download di malware e la condivisione di informazioni personali o sensibili. Attività di Social Engineering fanno leva sulla componente psicologica ed emotiva della vittima per ottenere gli obiettivi prefissati.

I valori associati a **Social Engineering** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

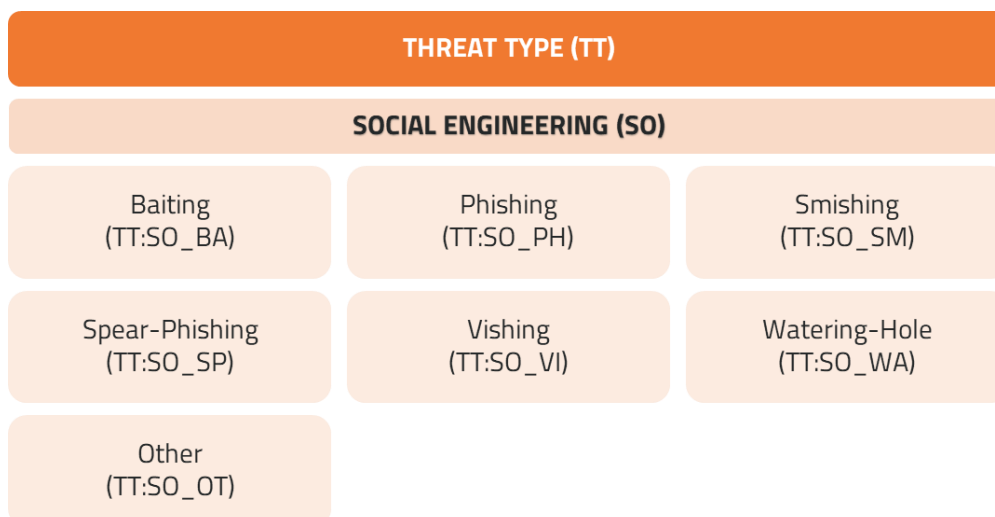


Figura 14: Predicato 'Social Engineering' con i relativi valori

3.2.8.1 Baiting (TT:SO_BA)

Baiting identifica attività fraudolente in cui un attore malevolo attira la vittima mediante un'esca, come la promessa della ricezione di un bene o l'ottenimento di un vantaggio. La superficie di attacco comprende sia il mondo online sia la vita reale. In questi casi, l'attaccante tenta di sfruttare la curiosità umana per convincere la vittima ad effettuare azioni quali, ad esempio, l'inserimento di dati personali su falsi servizi online, il download di malware occultato da applicazioni e contenuti leciti, oppure tramite dispositivi USB utilizzati come esca.

3.2.8.2 Phishing (TT:SO_PH)

Phishing identifica gli eventi cyber in cui un utente viene contattato, tramite e-mail o altri strumenti di messaggistica, da un attore malevolo allo scopo di condurre la vittima all'esecuzione di codice malevolo o a visitare risorse artefatte con lo scopo di carpire dati personali, bancari o credenziali di accesso, trasferire somme di denaro. Gli eventi di phishing possono anche essere il preludio o una componente di attacchi informatici più ampi e complessi.

3.2.8.3 Smishing (TT:SO_SM)

Smishing identifica gli eventi cyber in cui un utente viene contattato, tramite l'invio di brevi messaggi di testo (SMS), da un attore malevolo allo scopo di condurre la vittima all'esecuzione di codice malevolo come false applicazioni *mobile* o a visitare risorse artefatte con lo scopo di carpire dati personali, bancari o credenziali di accesso, trasferire somme di denaro. Gli eventi di smishing possono anche essere il preludio o una componente di attacchi informatici più ampi e complessi.

3.2.8.4 Spear-Phishing (TT:SO_SP)

Spear-Phishing è una tipologia di phishing contro target di specifico interesse che prevede l'invio di un messaggio altamente personalizzato da un account di posta elettronica apparentemente noto alla vittima, con l'intento di carpire informazioni sensibili, ovvero indurla ad aprire/scaricare

allegati o link malevoli. Allo spear-phishing possono essere associate tecniche di ingegneria sociale, tra cui il monitoraggio delle relazioni e delle abitudini sui social media del soggetto d'interesse.

3.2.8.5 Vishing (TT:SO_VI)

Vishing identifica gli eventi cyber in cui un utente viene contattato, tramite sistemi di comunicazione vocale, da un attore criminale allo scopo di condurre la vittima all'esecuzione di codice malevolo o di carpire dati aziendali, personali, bancari o credenziali di accesso, trasferire somme di denaro o anche solo come "ponte" per ulteriori attacchi.

3.2.8.6 Watering-Hole (TT:SO_WA)

Watering-Hole identifica gli eventi cyber nel quale un attaccante mira a compromettere un gruppo specifico di utenti attraverso l'infezione di siti web che sono noti per essere regolarmente visitati da tale gruppo. L'obiettivo di questa tipologia di attacchi è quello di colpire la vittima in modo indiretto tramite la compromissione dell'applicazione Web interessata.

3.2.8.7 Other (TT:SO_OT)

Other identifica gli eventi cyber relativi a Social Engineering non identificabili con gli altri valori definiti nel sottoinsieme.

3.2.9 Predicato: Vulnerability (VU)

Il predicato **Vulnerability** identifica quale tipologia di vulnerabilità interessa un determinato prodotto o servizio o è connessa ad uno specifico evento cyber.

I valori associati a **Vulnerability** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

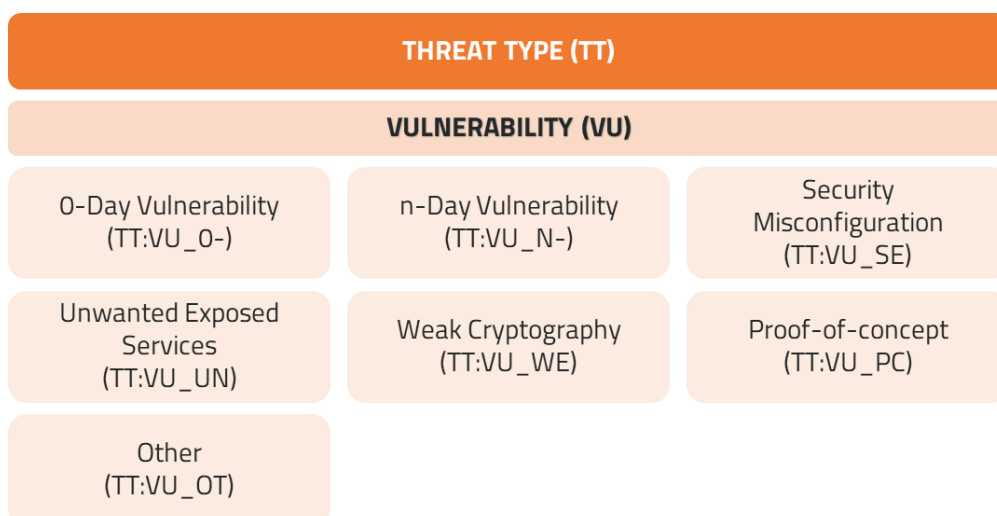


Figura 15: Predicato 'Vulnerability' con i relativi valori



3.2.9.1 0-Day Vulnerability (TT:VU_0-)

0-Day Vulnerability identifica che un determinato bene informatico è affetto da una vulnerabilità non nota pubblicamente, che quindi potrebbe essere sfruttata da un attaccante per compromettere un sistema informativo e minarne l'integrità, la riservatezza e la disponibilità.

3.2.9.2 n-Day Vulnerability (TT:VU_N-)

n-Day Vulnerability identifica una vulnerabilità 0-day che è stata resa pubblica da più di un giorno, indipendentemente dal rilascio del software correttivo. Generalmente, in questi casi, anche successivamente alla pubblicazione della falla di sicurezza un attaccante potrebbe sfruttare la vulnerabilità per compromettere i beni informatici affetti prima che venga attuata la risoluzione tramite il relativo aggiornamento o l'eventuale workaround.

3.2.9.3 Security Misconfiguration (TT:VU_SE)

Security Misconfiguration indica che la configurazione errata di un bene informatico può portare a rischi di sicurezza e provocare falle che possono essere facilmente sfruttate da un criminale informatico per compromettere un sistema. Alcuni esempi di Security Misconfiguration sono il mancato hardening dei sistemi, un'errata gestione dei permessi o l'installazione e abilitazione di funzionalità non adeguatamente protette.

3.2.9.4 Unwanted Exposed Services (TT:VU_UN)

Unwanted Exposed Services indica che il bene informatico coinvolto nell'evento di sicurezza espone servizi di rete generalmente non raccomandati in quanto in grado di ampliare la superficie di attacco e, se non adeguatamente protetti, possono inficiare sulla postura di sicurezza. Si tratta di servizi sfruttabili da attori malevoli per penetrare all'interno della rete delle vittime o tali da agevolare, ad esempio, attacchi di tipo DDoS reflection.

3.2.9.5 Weak Cryptography (TT:VU_WE)

Weak Cryptography identifica gli eventi cyber relativi all'utilizzo improprio o non corretto dei meccanismi di sicurezza legati alla crittografia. Tecniche di cifratura che impiegano algoritmi di crittografia deboli possono fornire una sicurezza inadeguata contro gli attacchi informatici tali da comportare l'esposizione di dati sensibili, la perdita di chiavi, l'interruzione dell'autenticazione, sessioni non sicure e facilitare attacchi di spoofing.

3.2.9.6 Proof-of-concept (TT:VU_PC)

Proof-of-concept identifica, nel contesto della sicurezza informatica, la disponibilità di una dimostrazione tecnica realizzata per validare la presenza di una vulnerabilità teorica, dimostrando come essa possa essere sfruttata in un software o in un sistema informatico.

3.2.9.7 Other (TT:VU_OT)

Other identifica gli eventi cyber relativi a Vulnerability non identificabili con gli altri valori definiti

nel sottoinsieme.

3.3 THREAT ACTOR (TA)

3.3.1 Predicato: Adversary Motivation (AM)

Adversary Motivation identifica, se note al momento della condivisione, le motivazioni che hanno mosso l'attore malevolo nel compiere l'attività illecita o malevola.

I valori associati ad **Adversary Motivation** identificati dall'Agenzia per la tassonomia degli eventi sono elencati di seguito.

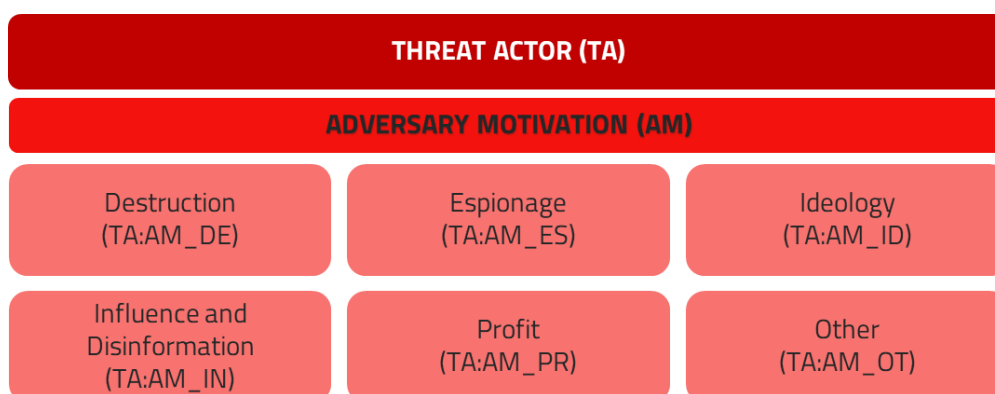


Figura 16: Predicato 'Adversary Motivation' con i relativi valori

3.3.1.1 Destruction (TA:AM_DE)

Destruction identifica gli eventi cyber nei quali un attaccante ha condotto attività malevole o illecite volte a danneggiare un bene informatico, al fine di comprometterne il funzionamento, di interrompere l'erogazione totale o parziale dei servizi forniti o di impedirne l'accesso al personale autorizzato. Un esempio di evento cyber dimostrativo per queste caratteristiche è rappresentato dagli attacchi che prevedono l'utilizzo di malware di tipo wiper (§ 3.2.7.16).

È importante evidenziare che gli eventi ransomware non possono essere identificati con questo valore poiché in tali casi, solitamente, l'avversario è mosso da interessi economici (§ 3.3.1.5) e pertanto non è interessato al mero danneggiamento.

3.3.1.2 Espionage (TA:AM_ES)

Espionage identifica gli eventi cyber nei quali un attaccante ha condotto un'attività indebita finalizzata all'acquisizione di dati/informazioni sensibili, proprietarie o classificate al fine di conseguire un guadagno economico, un vantaggio competitivo o per ragioni politiche. In questa categoria rientrano, ad esempio, la sottrazione di segreti industriali, di informazioni classificate o di proprietà intellettuale.

3.3.1.3 Ideology (TA:AM_ID)

Ideology identifica gli eventi cyber nei quali un attaccante ha condotto attività malevole o illecite per diffondere un messaggio di natura ideologica all'organizzazione colpita, ai fruitori del servizio impattato o a qualunque terza parte anche non direttamente coinvolta nell'illecito. Gli eventi cyber che appartengono a questa categoria vengono spesso compiuti dai cosiddetti hacktivisti. A tal proposito si rimanda al valore Hacktivist (§ 3.3.2.2) del predicato Adversary Type (§ 3.3.2).

3.3.1.4 Influence and Disinformation (TA:AM_IN)

Influence and Disinformation identifica gli eventi cyber nei quali avviene diffusione intenzionale di notizie o informazioni inesatte o distorte allo scopo di influenzare le azioni e le scelte di qualcuno.

3.3.1.5 Profit (TA:AM_PR)

Profit identifica gli eventi cyber in cui un attaccante o un gruppo effettua azioni malevole o illecite al fine di ottenerne in modo diretto o indiretto un profitto. Alcuni esempi:

- richiesta di riscatto in denaro in caso di ransomware;
- richiesta di riscatto in denaro in caso di sextortion;
- phishing finalizzato alla sottrazione di dati bancari;
- infezione con malware di tipo trojan bancari.

3.3.1.6 Other (TA:AM_OT)

Other identifica gli eventi cyber relativi ad Adversary Motivation non identificabili con gli altri valori definiti nel sottoinsieme.

3.3.2 Predicato: Adversary Type (AD)

Il predicato **Adversary Type** identifica, se nota al momento della condivisione, la tipologia di attaccante o gruppo che ha perpetrato le azioni malevole o illecite. Questo predicato non indica le motivazioni che hanno mosso l'avversario, per le quali è invece prevista la categoria Adversary Motivation (§ 3.3.1).

I valori associati ad **Adversary Type** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

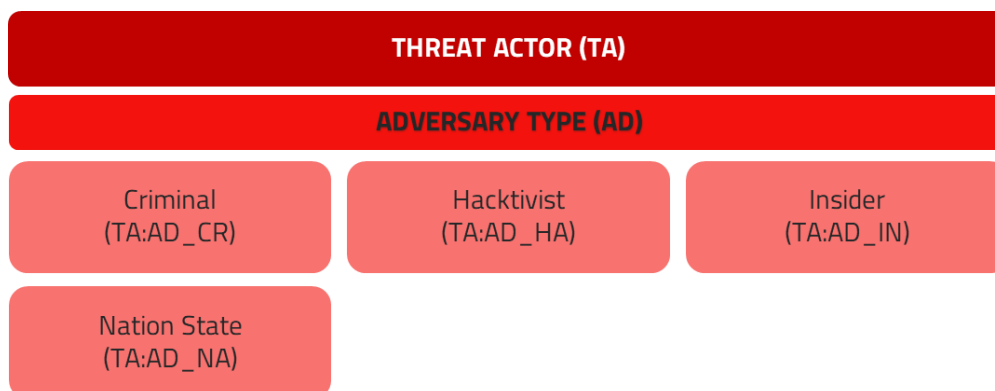


Figura 17: Predicato 'Adversary Type' con i relativi valori

3.3.2.1 Criminal (TA:AD_CR)

Criminal identifica gli eventi cyber in cui l'attaccante o il gruppo che ha causato l'evento può essere categorizzato nella tipologia più generica di "criminale" i cui scopi tendono a generare un profitto dalle azioni svolte.

3.3.2.2 Hacktivist (TA:AD_HA)

Hacktivist identifica gli eventi cyber in cui è previsto l'uso sovversivo di strumenti digitali al fine di promuovere un'agenda politica o principi di connotazione sociale. Questi gruppi utilizzano tecniche di hacking ad esempio per:

- attaccare siti web per compromettere l'erogazione di servizi o alterarne i contenuti per diffondere messaggi di natura politica o ideologica;
- pubblicare dati governativi classificati per denunciare la mancanza di protezione dei dati da parte delle autorità;
- reindirizzare gli utenti su siti gestiti dagli attivisti digitali per diffondere la propria ideologia.

3.3.2.3 Insider (TA:AD_IN)

Insider identifica gli eventi cyber in cui un attaccante utilizza le proprie autorizzazioni o le conoscenze acquisite durante le consuete attività lavorative per compiere un attacco informatico dall'interno della rete dalla quale opera. L'obiettivo di un insider può essere ad esempio il furto di informazioni sensibili, il danneggiamento di un sistema, il sabotaggio dell'azienda o la vendita delle informazioni trafugate.

3.3.2.4 Nation State (TA:AD_NA)

Nation State identifica gli eventi cyber condotti da entità o gruppi statuali o sponsorizzati dallo Stato, ossia gruppi che conducono operazioni cibernetiche avanzate per conto di un governo o di uno Stato sovrano. Questi attori sono sostenuti o autorizzati dal governo del loro paese per perseguire obiettivi di interesse nazionale attraverso attività di hacking, spionaggio o guerra cibernetica. Questa tipologia di avversario dispone solitamente di risorse significative, tra cui

personale altamente qualificato, budget cospicui e accesso a strumenti e tecnologie avanzate.

3.4 ADDITIONAL CONTEXT (AC)

3.4.1 Predicato: Abusive Content (AB)

Nell'ambito di un evento di sicurezza informatica, il predicato **Abusive Content** identifica la presenza di materiale offensivo, illegale o non voluto inviato ad un utente con finalità di ferirne la sensibilità o la dignità. La diffusione di tale materiale può avvenire in maniera diretta, ad esempio tramite e-mail o sms, o in maniera indiretta, ad esempio tramite popup o pubblicità su Internet.

I valori associati a **Abusive Content** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

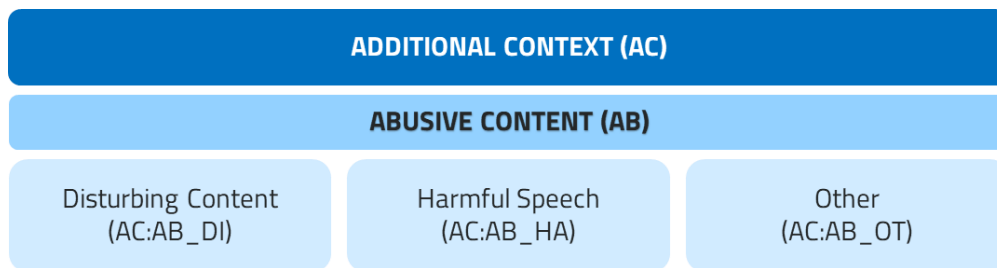


Figura 18: Predicato 'Abusive Content' con i relativi valori

3.4.1.1 Disturbing Content (AC:AB_DI)

Disturbing Content identifica qualsiasi tipo di materiale o informazione diffusa tramite sistemi informatici che può essere considerato offensivo, inappropriato, dannoso o che possa provocare disagio psicologico o emotivo.

3.4.1.2 Harmful Speech (AC:AB_HA)

Harmful speech identifica eventi qualsiasi forma di comunicazione espressa tramite piattaforme digitali che può causare danno, disagio o discriminazione a individui o gruppi. Tra questi, discorsi corredate da argomenti offensivi quali bullismo, molestie, mobbing, diffamazione o discriminazione contro uno o più soggetti, con il possibile intento di discreditarne e/o diffamare pubblicamente la vittima.

3.4.1.3 Other (AC:AB_OT)

Other identifica gli eventi cyber relativi ad Abusive Content non identificabili con gli altri valori definiti nel sottoinsieme.

3.4.2 Predicato: Asset Source Geography (AS)

Il predicato **Asset Source Geography** identifica la localizzazione geografica di beni informatici coinvolti in eventi cyber che sono stati identificati come "sorgenti" di attività malevole o illecite.

I valori associati ad **Asset Source Geography** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

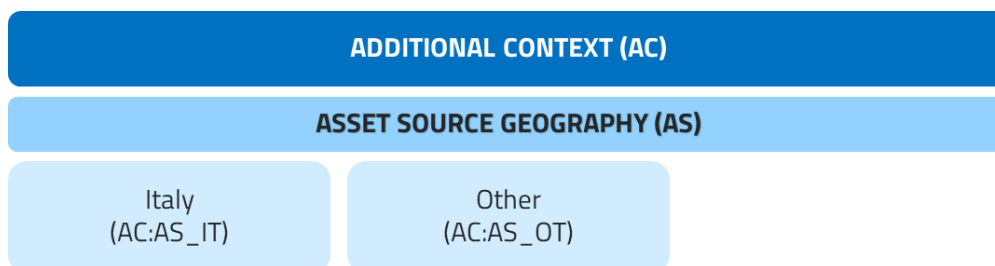


Figura 19: Predicato 'Asset source geography' con i relativi valori

3.4.2.1 Italy (AC:AS_IT)

Italy indica che i beni informatici da cui sono state condotte attività malevole o illecite sono localizzati sul territorio nazionale italiano.

3.4.2.2 Other (AC:AS_OT)

Other indica che i beni informatici da cui sono state condotte attività malevole o illecite sono localizzati al di fuori del territorio nazionale italiano.

3.4.3 Predicato: Involved Asset (IN)

Il predicato **Involved Asset** identifica le risorse coinvolte nell'evento cyber. I valori relativi a questo predicato possono indicare una o più risorse interessate dall'evento, anche in assenza di impatto.

Vista la numerosità dei valori associati al predicato Involved Asset, essi sono stati suddivisi in 19 sotto-predicati, ai fini di facilitare la rapida individuazione dei valori richiesti.

I sotto-predicati associati a **Involved Asset**, e i relativi valori, identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

Hardware – Network Device (HW-ND)

Il **sotto-predicato Hardware – Network Device** identifica le componenti hardware che costituiscono l'infrastruttura di rete. Tali componenti, collegati da appositi canali di comunicazione (link), forniscono un servizio di comunicazione che permette lo scambio e la condivisione di dati tra più utenti, dispositivi distribuiti o terminali (host).

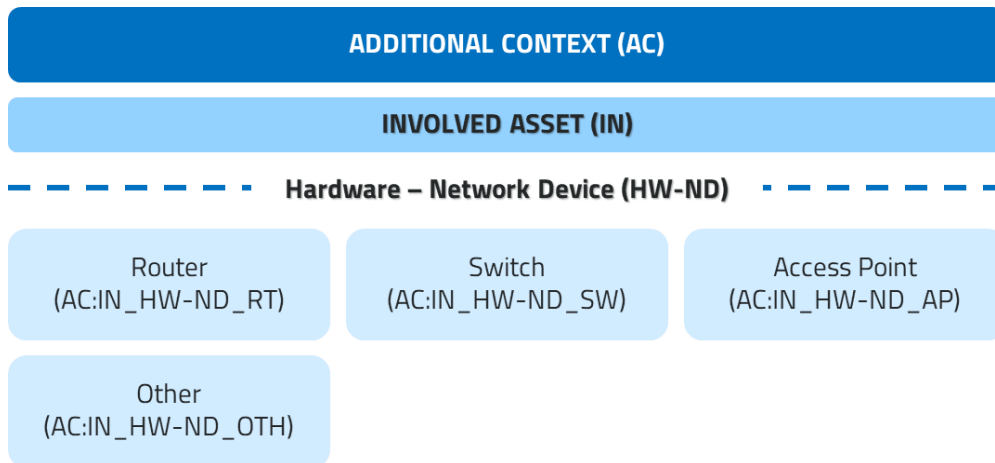


Figura 20: Sotto-predicato 'Hardware - Network Device' con i relativi valori

3.4.3.1 Router (AC:IN_HW-ND_RT)

Router identifica un dispositivo che, in una rete informatica, si occupa di incanalare il traffico tra due o più dispositivi connessi alla stessa rete o nelle sottoreti.

3.4.3.2 Switch (AC:IN_HW-ND_SW)

Switch identifica un dispositivo all'interno di una rete di computer che gestisce il flusso di dati da e verso i computer connessi, attraverso porte di ingresso e di uscita.

3.4.3.3 Access Point (AC:IN_HW-ND_AP)

Access Point identifica un dispositivo hardware di rete che permette ai dispositivi Wi-Fi di connettersi a una rete cablata.

3.4.3.4 Other (AC:IN_HW-ND_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato Hardware_Network Device non identificabili con gli altri valori definiti nel sottoinsieme.

----- Hardware - IoT/IloT (HW-IT) -----

Il **sotto-predicato Hardware - IoT/IloT** identifica sensori, strumenti, macchine e altri dispositivi collegati in rete tra loro – utilizzati anche in ambito industriale – che utilizzano la connettività Internet per comunicare, scambiare dati e monitorare processi.

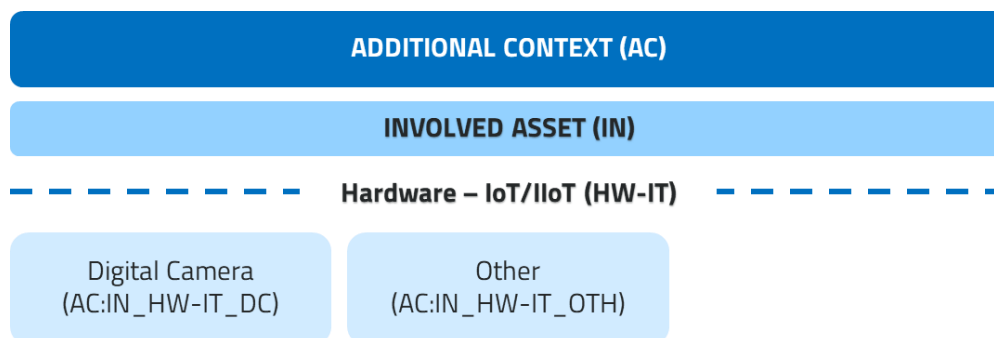


Figura 21: Sotto-predicato "Hardware - IoT/IloT" con i relativi valori

3.4.3.5 Digital Camera (AC:IN_HW-IT_DC)

Digital Camera identifica un dispositivo elettronico capace di catturare e trasmettere immagini e video.

3.4.3.6 Other (AC:IN_HW-IT_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Hardware – IoT/IloT** non identificabili con gli altri valori definiti nel sottoinsieme.

Hardware – Security Appliance (HW-SA)

Il **sotto-predicato Hardware – Security Appliance** identifica un insieme di dispositivi mediante i quali si attua la protezione dei dati, delle reti e dei sistemi informatici rispetto ad accessi non autorizzati, danni, interruzioni o altri rischi

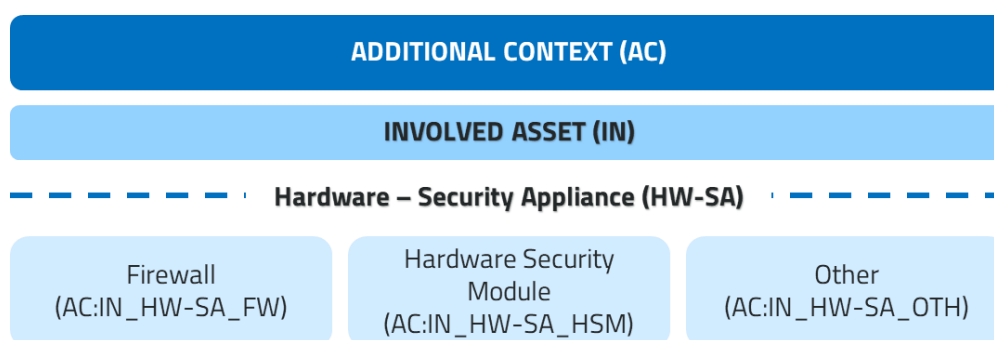


Figura 22: Sotto-predicato "Hardware - Security Appliance" con i relativi valori

3.4.3.7 Firewall (AC:IN_HW-SA_FW)

Firewall identifica un dispositivo o sistema di rete che permette di monitorare e segregare il traffico in entrata ed in uscita, impedendo il traffico di dati non autorizzato tra due reti connesse e proteggendo le risorse di sistema della rete da potenziali minacce esterne.

3.4.3.8 Hardware Security Module (AC:IN_HW-SA_HSM)

Hardware Security Module identifica un dispositivo informatico fisico che garantisce la salvaguardia e la gestione di chiavi digitali, nonché l'elaborazione crittografica, a prova di manomissione e di intrusione.

3.4.3.9 Other (AC:IN_HW-SA_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Hardware – Security Appliance** non identificabili con gli altri valori definiti nel sottoinsieme.

----- Hardware – Computer System (HW-CS) -----

Il **sotto-predicato Hardware – Computer System** identifica un insieme di componenti hardware che permettono di elaborare e trasmettere i dati.

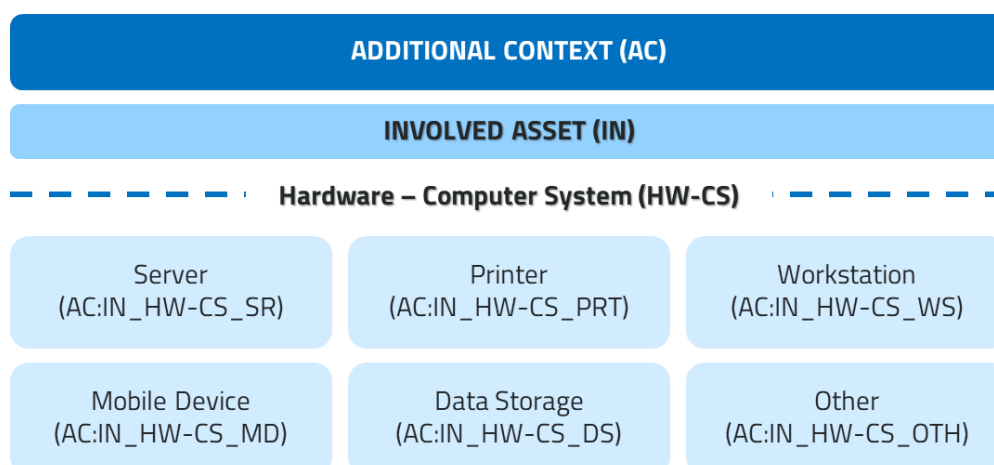


Figura 23: Sotto-predicato "Hardware - Computer System" con i relativi valori

3.4.3.10 Server (AC:IN_HW-CS_SR)

Server identifica un dispositivo fisico o sistema informatico di elaborazione e gestione del traffico di informazioni su una rete, che permette la fruizione delle informazioni da parte dei dispositivi connessi alla stessa rete.

3.4.3.11 Printer (AC:IN_HW-CS_PRT)

Printer identifica un dispositivo che converte i dati digitali in testo su un supporto cartaceo.

3.4.3.12 Workstation (AC:IN_HW-CS_WS)

Workstation identifica un dispositivo informatico volto a soddisfare le esigenze di elaborazione di un singolo utente. Viene utilizzato per attività quali la programmazione, l'ingegneria e la progettazione.

3.4.3.13 Mobile Device (AC:IN_HW-CS_MD)

Mobile Device identifica dei dispositivi elettronici pienamente utilizzabili e funzionali alla mobilità dell'utente (es. smartphone, tablet, lettori di e-book ecc.) con caratteristiche di elaborazione o accesso ai dati prive di vincoli sulla posizione fisica dell'utente.

3.4.3.14 Data Storage (AC:IN_HW-CS_DS)

Data Storage identifica hardware elettronico, elettrostatico o elettrico o altri elementi che consentono l'inserimento di dati e il recupero degli stessi.

3.4.3.15 Other (AC:IN_HW-CS_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Hardware - Computer System** non identificabili con gli altri valori definiti nel sottoinsieme.

Hardware – OT (HW-OT)

Il **sotto-predicato Hardware – OT** identifica un insieme di componenti hardware necessari al monitoraggio e controllo di processi fisici e sistemi produttivi nel dominio dell'Operational Technology.

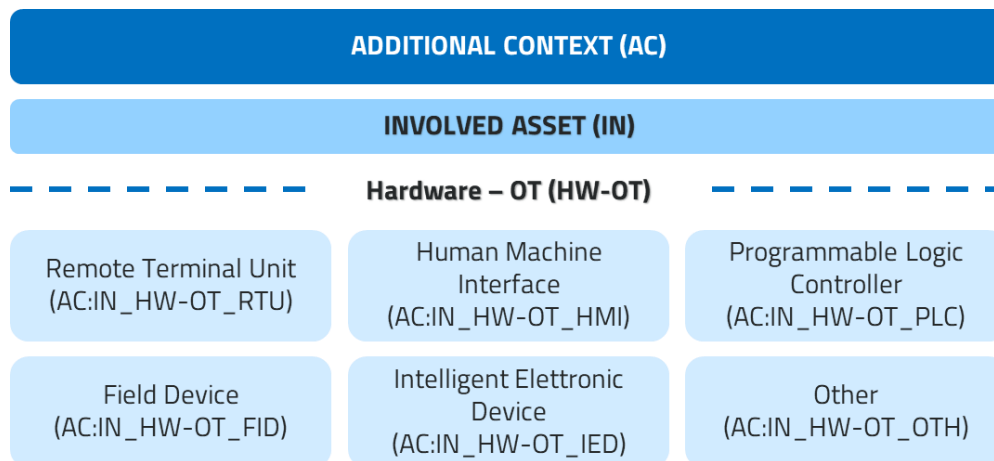


Figura 24: Sotto-predicato "Hardware - OT" con i relativi valori

3.4.3.16 Remote Terminal Unit (AC:IN_HW-OT_RTU)

Remote Terminal Unit identifica unità remote in grado di ricevere e decodificare i messaggi provenienti dal sistema centrale di controllo. Sono in grado di controllare un insieme di componenti elettronici/elettromeccanici e forniscono informazioni sui dispositivi connessi confrontandone gli stati con le richieste pervenute. Possono avere capacità di rete, inclusi collegamenti radio cablati e senza fili per comunicare con il sistema di controllo centrale.

3.4.3.17 Human Machine Interface (AC:IN_HW-OT_HMI)

Human Machine Interface identifica una interfaccia hardware che permette agli operatori di interagire con un controllore in modo da monitorare e controllare i processi, configurare le impostazioni e visualizzare le informazioni sullo stato e la storia dei processi.

3.4.3.18 Programmable Logic Controller (AC:IN_HW-OT_PLC)

Programmable Logic Controller identifica un sistema elettronico a funzionamento digitale, destinato all'uso in ambito industriale. Possiede moduli di Input/Output (I/O) digitali e analogici e utilizza una memoria programmabile per l'archiviazione delle istruzioni necessarie all'implementazione di funzioni specifiche (logiche, sequenziamento, temporizzazione, conteggio e calcolo) e dei controlli per vari tipi di macchine e processi.

3.4.3.19 Field Device (AC:IN_HW-OT_FID)

Field Device identifica un insieme di apparecchiature quali attuatori, sensori, network controller e convertitori di segnali destinati all'uso in ambito industriale. Tali dispositivi trovano le loro applicazioni all'interno delle architetture associate agli Industrial Control Systems (ICS), Distributed Control Systems (DCS), Building automation Systems (BAS), Physical Access Control Systems (PACS).

3.4.3.20 Intelligent Elettronic Device (AC:IN_HW-OT_IED)

Intelligent Elettronic Device identifica un dispositivo che incorpora una o più unità di elaborazione, in grado di ricevere e inviare dati/controlli da o verso altri dispositivi. Può essere utilizzato per eseguire controlli ed elaborazioni locali. Esempi di tali dispositivi sono i misuratori elettronici multifunzione, relè digitali e controllori.

3.4.3.21 Other (AC:IN_HW-OT_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato Hardware - OT non identificabili con gli altri valori definiti nel sottoinsieme.

Hardware – Other (HW-OH)

Il **sotto-predicato Hardware – Other** racchiude tutti gli elementi **hardware** che non sono stati racchiusi o classificati nei sotto-predicati precedenti.

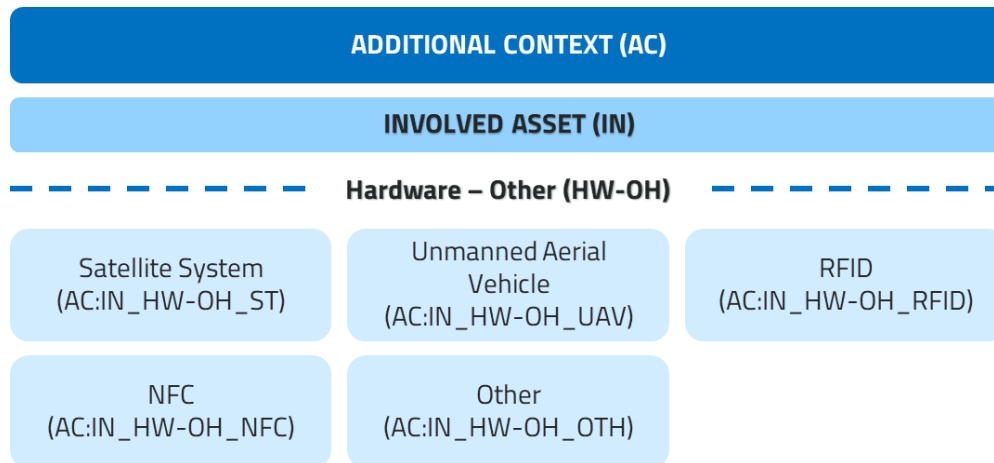


Figura 25: Sotto-predicato "Hardware - Other" con i relativi valori

3.4.3.22 Satellite System (AC:IN_HW-OH_ST)

Satellite System identifica un sistema di comunicazione in grado di ricevere segnali dalla Terra e di ritrasmetterli con l'uso di un transponder, un ricevitore e trasmettitore integrato di segnali radio. Un esempio di Satellite System è il GPS.

3.4.3.23 Unmanned Aerial Vehicle (AC:IN_HW-OH_UAV)

Unmanned Aerial Vehicle identifica velivoli controllati a distanza, in genere tramite un controllore a terra o un sistema computerizzato, utilizzati senza un pilota umano a bordo. Utilizzati per scopi di ricognizione, sorveglianza, e acquisizione di obiettivi.

3.4.3.24 RFID (AC:IN_HW-OH_RFID)

RFID identifica una tecnologia di riconoscimento e validazione e/o memorizzazione automatica di informazioni a distanza basata sulla memorizzazione di dati in particolari dispositivi elettronici passivi, capaci di rispondere a chiamate di prossimità da parte di dispositivi attivi, sia fissi che portatili, chiamati reader.

3.4.3.25 NFC (AC:IN_HW-OH_NFC)

NFC identifica una tecnologia di ricetrasmissione che fornisce connettività senza fili (RF) bidirezionale a distanza (contactless) a corto raggio (fino a un massimo di 10 cm).

3.4.3.26 Other (AC:IN_HW-OH_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Hardware - Other** non identificabili con gli altri valori definiti nel sottoinsieme.

Hardware – Virtualization Infrastructure (HW-VI)

Il sotto-predicato **Hardware – Virtualization Infrastructure** identifica infrastrutture che

consentono di astrarre le componenti hardware, cioè fisiche, degli elaboratori al fine di renderle disponibili al software in forma di risorsa virtuale.

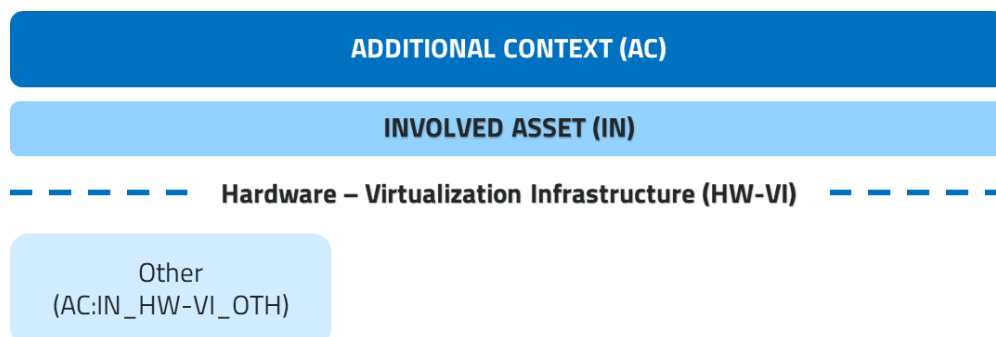


Figura 26: Sotto-predicato "Hardware - Virtualization Infrastructure" con i relativi valori

3.4.3.27 Other (AC:IN_HW-VI_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Hardware – Virtualization Infrastructure**.

Software – Security System (SW-SS)

Il **sotto-predicato Software – Security System** identifica i sistemi di protezione software in grado in filtrare e bloccare il traffico di dati su un sistema (es. antispam, antivirus, ecc.)

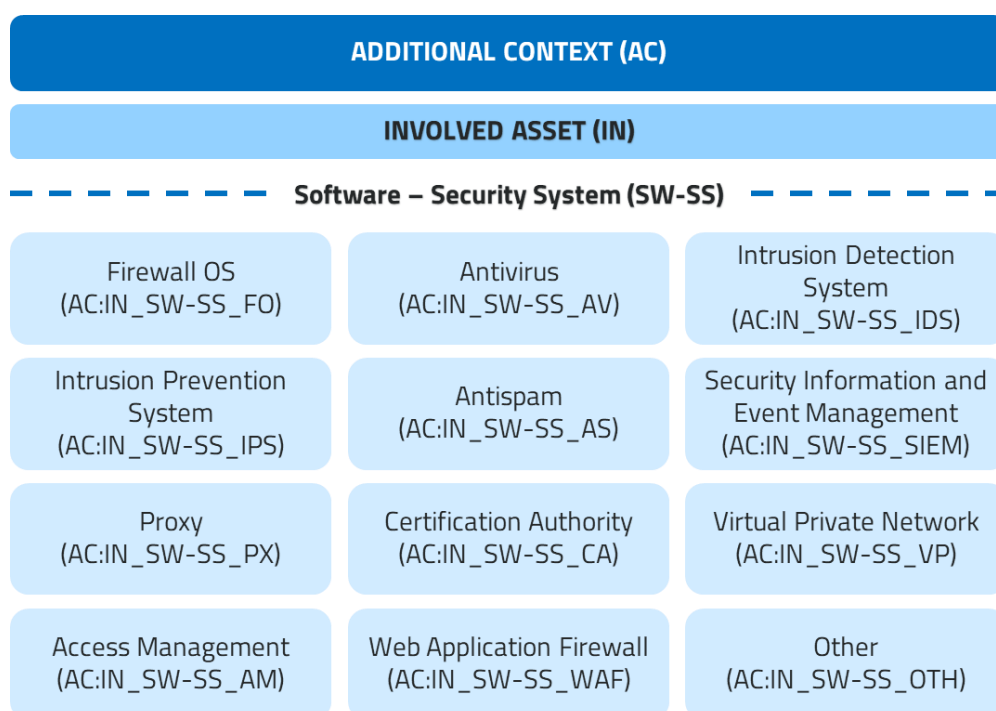


Figura 27: Sotto-predicato "Software - Security System" con i relativi valori



3.4.3.28 Firewall OS (AC:IN_SW-SS_FO)

Firewall OS identifica un sistema di rete e/o applicativo che permette di monitorare il traffico in entrata ed in uscita impedendo il traffico di dati non autorizzato tra due reti connesse e proteggendo le risorse di sistema della rete da potenziali minacce esterne.

3.4.3.29 Antivirus (AC:IN_SW-SS_AV)

Antivirus identifica un programma che monitora un computer o una rete per identificare tutti i principali tipi di malware e prevenire o contenere incidenti malware.

3.4.3.30 Intrusion Detection System (AC:IN_SW-SS_IDS)

Intrusion Detection System identifica un sistema di sicurezza che monitora e analizza gli eventi di rete o di sistema allo scopo di individuare e fornire avvisi sui tentativi di accesso alle risorse di sistema in modo non autorizzato.

3.4.3.31 Intrusion Prevention System (AC:IN_SW-SS_IPS)

Intrusion Prevention System identifica un sistema in grado di rilevare un'attività intrusiva e che può anche tentare di fermare l'attività, idealmente prima che raggiunga i suoi obiettivi.

3.4.3.32 Antispam (AC:IN_SW-SS_AS)

Antispam identifica un insieme di programmi o servizi che bloccano in modo preventivo le mail che potrebbero essere definite come spam.

3.4.3.33 Security Information and Event Management (AC:IN_SW-SS_SIEM)

Security Information and Event Management identifica un'applicazione che offre la possibilità di raccogliere dati di sicurezza dai componenti del sistema informativo e presentarli come informazioni utilizzabili tramite un'unica interfaccia.

3.4.3.34 Proxy (AC:IN_SW-SS_PX)

Proxy identifica un software che riceve le richieste da uno o più client (come browser o applicazioni) e le inoltra verso le destinazioni finali su Internet. Il proxy può filtrare, modificare o registrare le richieste e le risposte, migliorando la sicurezza, la privacy o le prestazioni della rete.

3.4.3.35 Certification Authority (AC:IN_SW-SS_CA)

Certification Authority identifica una entità attendibile che emette e revoca certificati di chiave pubblica.

3.4.3.36 Virtual Private Network (AC:IN_SW-SS_VP)

Virtual Private Network identifica una rete virtuale costruita sopra le reti esistenti che può fornire un meccanismo di comunicazione sicuro per i dati e le informazioni IP trasmesse tra le reti.

3.4.3.37 Access Management (AC:IN_SW-SS_AM)

Access Management identifica un insieme di processi e applicazioni che consentono la gestione degli accessi per autenticare, autorizzare e verificare l'accesso alle applicazioni e sistemi IT. Esempi di access management sono: Policy Administration, Authentication, and Authorization.

3.4.3.38 Web Application Firewall (AC:IN_SW-SS_WAF)

Web Application Firewall identifica un dispositivo di sicurezza che monitora, filtra e blocca il traffico HTTP/HTTPS da e verso le applicazioni web. Il WAF protegge le applicazioni web da attacchi comuni, come, ad esempio, SQL injection, cross-site scripting (XSS) e altri attacchi a livello di applicazione.

3.4.3.39 Other (AC:IN_SW-SS_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Software – Security System** non identificabili con gli altri valori definiti nel sottoinsieme.

— — — — — Software – Data Management (SW-DM) — — — — —

Il **sotto-predicato Software – Data Management** identifica il processo di raccolta, organizzazione e accesso ai dati al fine di supportare la produttività, l'efficienza e il processo decisionale.

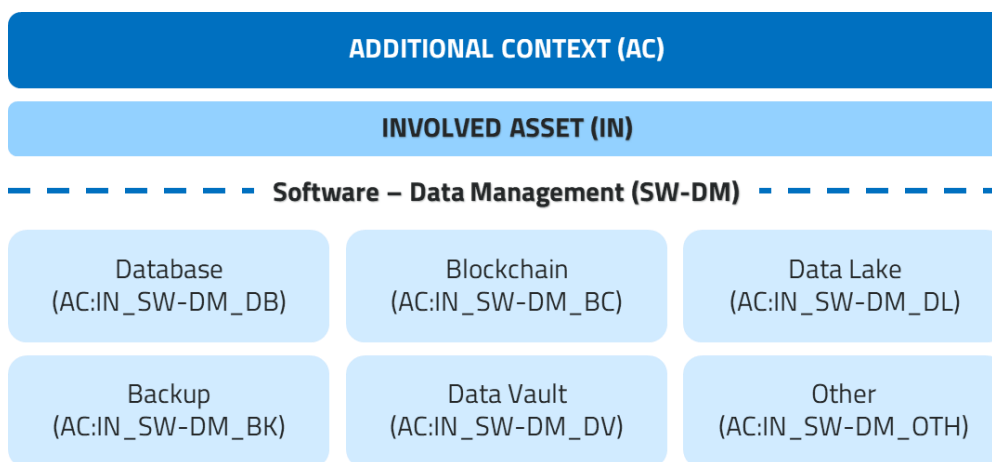


Figura 28: Sotto-predicato "Software - Data Management" con i relativi valori

3.4.3.40 Database (AC:IN_SW-DM_DB)

Database identifica un archivio di informazioni o dati immagazzinati e accessibili per via elettronica.

3.4.3.41 Blockchain (AC:IN_SW-DM_BC)

Blockchain identifica una sottofamiglia di tecnologie che consentono la creazione e la gestione di un registro aperto e distribuito per il tracciamento delle transazioni effettuate tra parti, costituito

da blocchi contenenti sequenze di dati (token) protetti da crittografia e immutabili.

3.4.3.42 Data Lake (AC:IN_SW-DM_DL)

Data Lake identifica un repository centralizzato che consente di archiviare grandi quantità di dati nel loro formato nativo, siano essi strutturati, semi-strutturati o non strutturati

3.4.3.43 Backup (AC:IN_SW-DM_BK)

Backup identifica il processo di messa in sicurezza delle informazioni di un sistema informatico attraverso la creazione di copie di file e programmi realizzati per facilitarne il recupero.

3.4.3.44 Data Vault (AC:IN_SW-DM_DV)

Data Vault identifica un modello di data warehousing progettato per fornire una struttura robusta e scalabile per l'integrazione di dati provenienti da diverse fonti.

3.4.3.45 Other (AC:IN_SW-DM_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Software – Data Management** non identificabili con gli altri valori definiti nel sottoinsieme.

----- Software – OT (SW-OT) -----

Il **sotto-predicato Software – OT** identifica un insieme di componenti software necessarie al monitoraggio e controllo di processi fisici e sistemi produttivi nel dominio dell'Operational Technology.

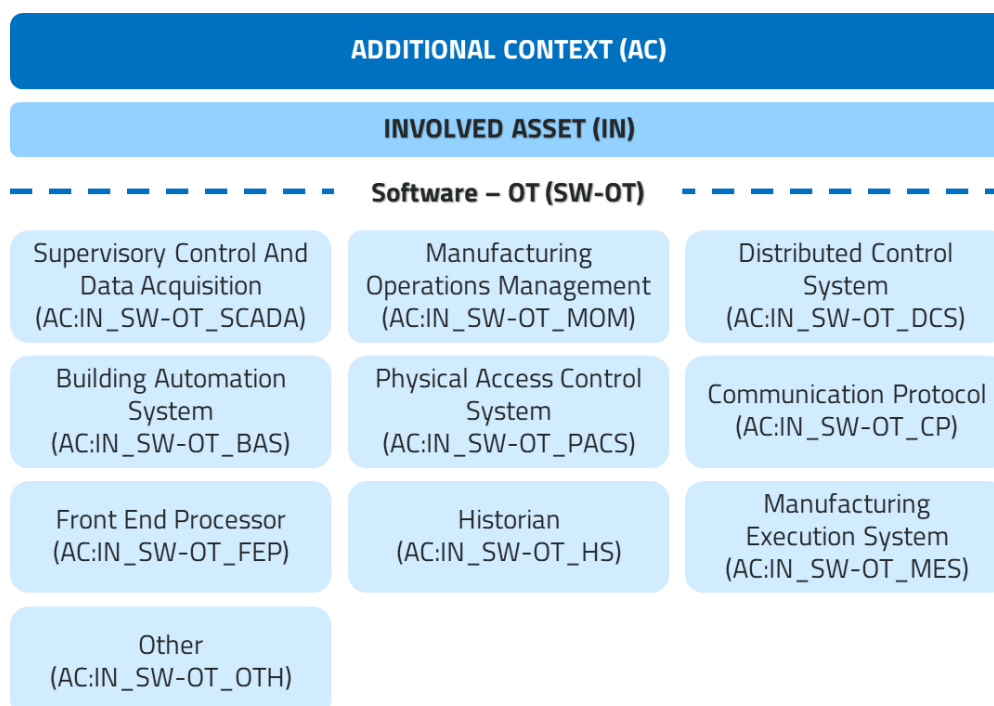


Figura 29: Sotto-predicato "Software - OT" con i relativi valori

3.4.3.46 Supervisory Control And Data Acquisition (AC:IN_SW-OT_SCADA)

Supervisory Control And Data Acquisition identifica un sistema computerizzato che raccoglie ed elabora dati a distanza, consentendo il controllo di processi e impianti complessi. Tale sistema è condiviso tra diversi siti o impianti per consentire una gestione centralizzata e la supervisione dei sistemi fisici.

3.4.3.47 Manufacturing Operations Management (AC:IN_SW-OT_MOM)

Manufacturing Operations Management identifica i sistemi che gestiscono le operazioni di produzione.

3.4.3.48 Distributed Control System (AC:IN_SW-OT_DCS)

Distributed Control System identifica un sistema di controllo impiegato in ambito industriale e legato a sistemi di produzione localizzati in una stessa area geografica (esempio: raffinerie di petrolio, trattamento acque, generazione di energia elettrica, produzione chimica, automobilistica e farmaceutica).

3.4.3.49 Building Automation System (AC:IN_SW-OT_BAS)

Building Automation System identifica un sistema di automazione relativo al controllo degli edifici, utilizzato per monitorare e ottimizzare l'uso e l'efficienza dei sottosistemi associati (HVAC, raccolta fumi, vapore, acqua calda, acqua refrigerata, sprinkler e monitoraggio elettrico). Consente agli operatori di accedere, controllare e monitorare tutti i sistemi da un'unica interfaccia, segnalando eventuali anomalie

3.4.3.50 Physical Access Control System (AC:IN_SW-OT_PACS)

Physical Access Control System identifica un sistema elettronico di sicurezza fisica che controlla l'accesso alle aree protette tramite opportuna autenticazione e/o autorizzazione.

3.4.3.51 Communication Protocol (AC:IN_SW-OT_CP)

Communication Protocol identifica un insieme di regole che definiscono le modalità di comunicazione tra due o più entità. Ogni protocollo è progettato con precisi compiti e finalità, a seconda delle entità interessate e del mezzo di comunicazione.

3.4.3.52 Front End Processor (AC:IN_SW-OT_FEP)

Front End Processor identifica un gateway che permette di interfacciare le HMI con diversi sottosistemi generalmente distribuiti in impianti di grandi dimensioni.

3.4.3.53 Historian (AC:IN_SW-OT_HS)

Historian identifica un database centralizzato progettato per raccogliere, memorizzare e supportare l'analisi dei dati utilizzando le tecniche di controllo statistico dei processi.

3.4.3.54 Manufacturing Execution System (AC:IN_SW-OT_MES)

Manufacturing Execution System identifica i sistemi utilizzati per raccogliere dati in tempo reale per ottimizzare la produzione.

3.4.3.55 Other (AC:IN_SW-OT_OTH)

Other racchiude tutti gli asset afferenti al **sotto-predicato Software – OT** non identificabili con gli altri valori definiti nel sottoinsieme.

— — — — — Software – Operating System (SW-OS) — — — — —

Il **sotto-predicato Software – Operating System** identifica il software di base che gestisce le risorse hardware e software di un computer.

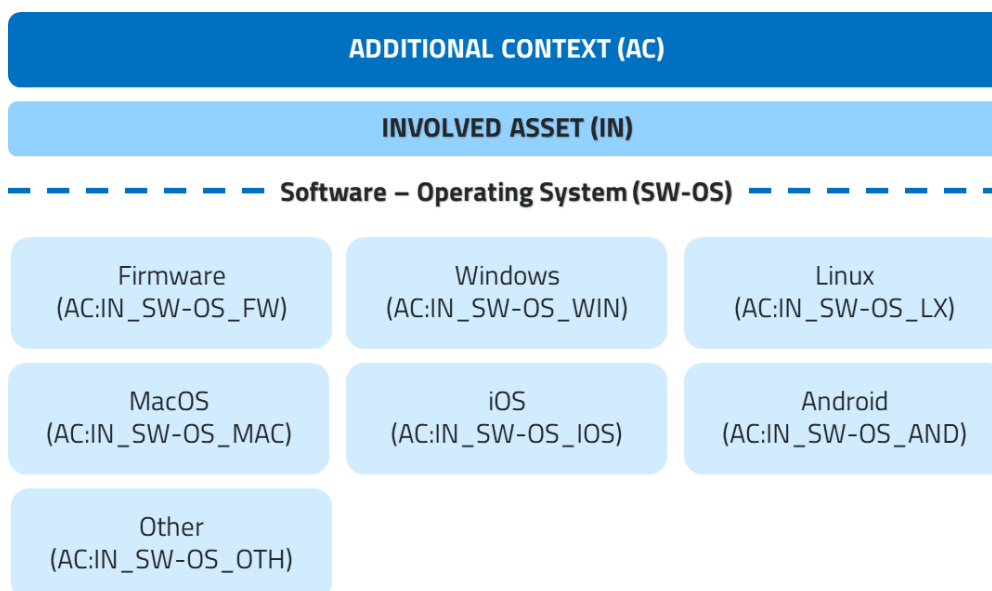


Figura 30: Sotto-predicato "Software - Operating System" con i relativi valori

3.4.3.56 Firmware (AC:IN_SW-OS_FW)

Firmware identifica l'insieme di programmi o di microprogrammi contenuti in una memoria a sola lettura (ROM), che presiedono alle sue fondamentali attività di funzionamento (controlli d'avvio, gestione delle unità periferiche, istruzioni di base, ecc.).

3.4.3.57 Windows (AC:IN_SW-OS_WIN)

Windows identifica il sistema operativo proprietario progettato da Microsoft per gestire e organizzare le risorse hardware e software di un computer e per fornire una piattaforma per l'esecuzione di applicazioni.

3.4.3.58 Linux (AC:IN_SW-OS_LX)

Linux identifica l'insieme di sistemi operativi Unix-like gratuiti e open source derivanti da Linux Kernel; permette di gestire e organizzare le risorse hardware e software di un computer e per fornire una piattaforma per l'esecuzione di applicazioni.

3.4.3.59 MacOS (AC:IN_SW-OS_MAC)

MacOS identifica il sistema operativo proprietario sviluppato da Apple Inc. basato su Unix, permette di gestire e organizzare le risorse hardware e software di un computer e per fornire una piattaforma per l'esecuzione di applicazioni.

3.4.3.60 iOS (AC:IN_SW-OS_IOS)

iOS identifica il sistema operativo mobile proprietario sviluppato da Apple esclusivamente per il proprio hardware, permette di gestire, organizzare ed eseguire le applicazioni mobile.

3.4.3.61 Android (AC:IN_SW-OS_AND)

Android identifica il sistema operativo mobile proprietario sviluppato da Google per programmare i dispositivi mobili, permette di gestire, organizzare ed eseguire le applicazioni mobile.

3.4.3.62 Other (AC:IN_SW-OS_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Software – Operating System** non identificabili con gli altri valori definiti nel sottoinsieme.

— — — — — Software – Virtualization Software (SW-VS) — — — — —

Il sotto-predicato **Software – Virtualization Software** identifica il software che consente ad una singola unità fisica di eseguire più macchine virtuali.

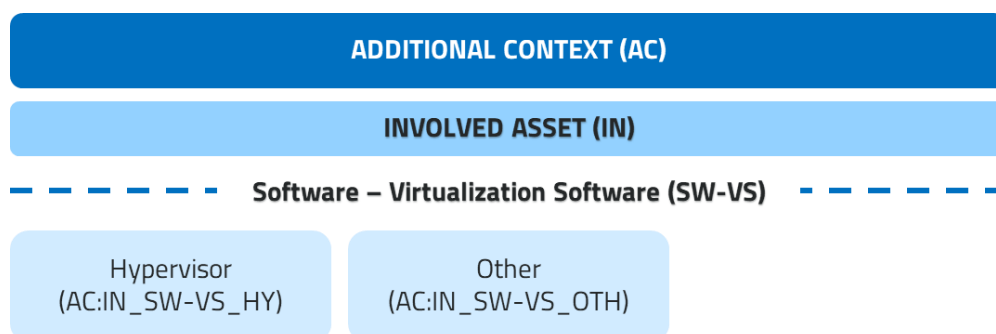


Figura 31: Sotto-predicato "Software - Virtualization Software" con i relativi valori

3.4.3.63 Hypervisor (AC:IN_SW-VS_HY)

Hypervisor, o virtual machine monitor (VMM), identifica un software, firmware o hardware che



crea e gestisce macchine virtuali (VM). Consente a più sistemi operativi di funzionare contemporaneamente su un singolo host fisico, condividendo le risorse hardware sottostanti.

3.4.3.64 *Other (AC:IN_SW-VS_OTH)*

Other racchiude tutti gli asset afferenti al sotto-predicato **Software – Virtualization Software** non identificabili con gli altri valori definiti nel sottoinsieme.

— — — — — Software – IoT/IloT (SW-IT) — — — — —

Il **sotto-predicato Software – IoT/IloT** identifica un insieme di componenti software per la gestione di sensori, strumenti, macchine e altri dispositivi collegati in rete tra loro – utilizzati anche in ambito industriale – che utilizzano la connettività Internet per comunicare, scambiare dati e monitorare processi.

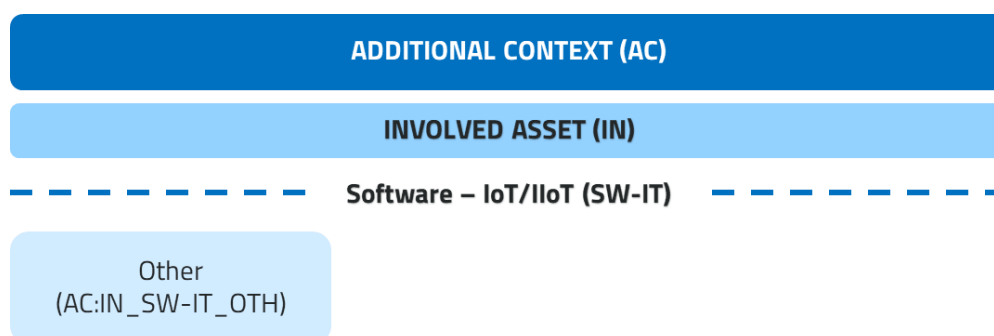


Figura 32: Sotto-predicato "Software - IoT/IloT" con i relativi valori

3.4.3.65 *Other (AC:IN_SW-IT_OTH)*

Other racchiude tutti gli asset afferenti al sotto-predicato **Software – IoT/IloT**.

— — — — — Software – Application (SW-AP) — — — — —

Il **sotto-predicato Software – Application** identifica un tipo di software che consente di eseguire specifiche funzioni su dispositivi come computer, smartphone o tablet, supportando l'utente in attività come la produttività, la comunicazione, l'elaborazione multimediale e la gestione dei dati.

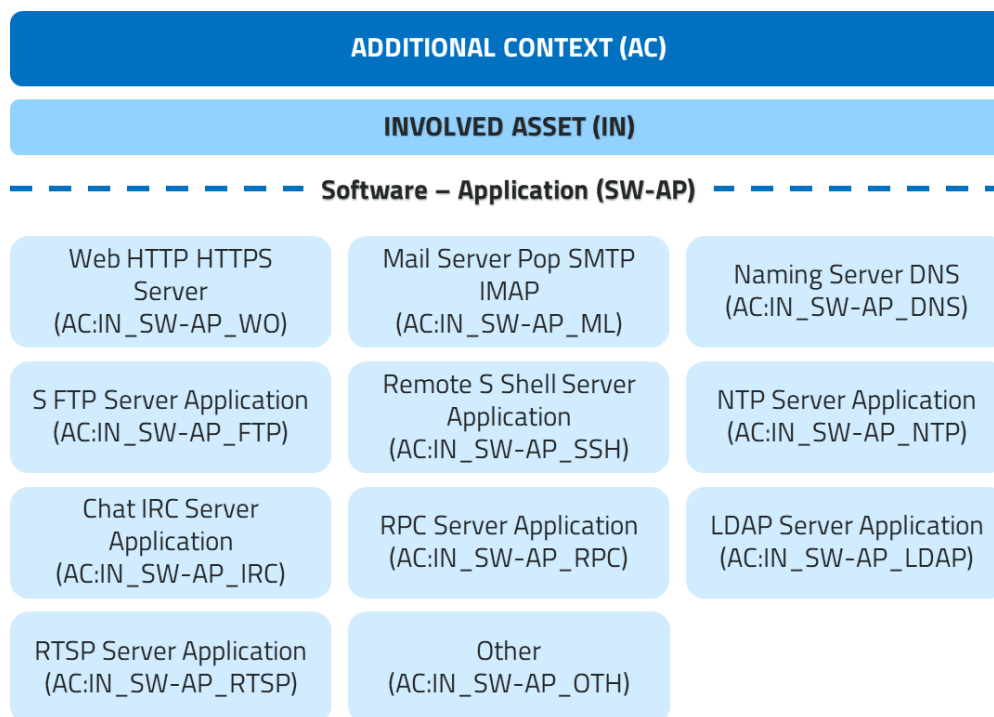


Figura 33: Sotto-predicato "Software - Application" con i relativi valori

3.4.3.66 Web HTTP HTTPS Server (AC:IN_SW-AP_WO)

Web HTTP HTTPS Server identifica un dispositivo che fornisce servizi del World Wide Web (WWW) su Internet. Include l'hardware, il sistema operativo, il software del server Web e il contenuto del sito Web (pagine Web).

3.4.3.67 Mail Server Pop SMTP IMAP (AC:IN_SW-AP_ML)

Mail Server Pop SMTP IMAP identifica un host che fornisce le funzionalità di una "posta elettronica". Memorizza la posta in arrivo per la distribuzione agli utenti e inoltra la posta in uscita.

3.4.3.68 Naming Server DNS (AC:IN_SW-AP_DNS)

Naming Server DNS identifica un dispositivo che mantiene un elenco di nomi di dominio, come definito dal Sistema dei Nomi di Dominio (DNS), e li traduce in indirizzi Internet Protocol.

3.4.3.69 S FTP Server Application (AC:IN_SW-AP_FTP)

S FTP Server Application identifica uno standard utilizzato per accedere a una rete, elencare directory e copiare file. Fornisce l'autenticazione dell'utente e consente agli utenti di trasferire file ed elencare directory.

3.4.3.70 Remote S Shell Server Application (AC:IN_SW-AP_SSH)

Remote S Shell Server Application identifica un programma che, in esecuzione su un computer o server, ascolta le connessioni in entrata da client remoti. Una volta stabilita la connessione,

l'applicazione server fornisce al client una shell interattiva, consentendo all'utente remoto di eseguire comandi e gestire il sistema come se fosse fisicamente presente.

3.4.3.71 NTP Server Application (AC:IN_SW-AP_NTP)

NTP Server Application identifica un'applicazione che fornisce il servizio di sincronizzazione dell'orario su una rete utilizzando il protocollo NTP, con lo scopo di distribuire un orario preciso a dispositivi e sistemi connessi.

3.4.3.72 Chat IRC Server Application (AC:IN_SW-AP_IRC)

Chat IRC Server Application identifica un programma che, in esecuzione su un server, facilita la comunicazione testuale tra client IRC. Agisce come punto di collegamento centrale, ricevendo e distribuendo messaggi tra gli utenti connessi, organizzati in "canali" di discussione.

3.4.3.73 RPC Server Application (AC:IN_SW-AP_RPC)

RPC Server Application identifica un programma che consente di eseguire una procedura su un server remoto, trasferendo il flusso di controllo e alcuni argomenti dal client al server, eseguendo la richiesta e restituendo i risultati.

3.4.3.74 LDAP Server Application (AC:IN_SW-AP_LDAP)

LDAP Server Application identifica un'interfaccia server-to-server per lo scambio di informazioni tra directory, ideata come un'implementazione a basso costo e più semplice del protocollo di accesso alla directory X.500. Facilita l'implementazione della replica e della concatenazione tra directory dissimili.

3.4.3.75 RTSP Server Application (AC:IN_SW-AP_RTSP)

RTSP Server Application identifica un programma che, in esecuzione su un server, consente ai client di controllare la riproduzione di flussi audio e video in streaming. Utilizza il protocollo RTSP per stabilire e gestire sessioni di streaming, consentendo ai client di avviare, mettere in pausa, interrompere e controllare la riproduzione di contenuti multimediali.

3.4.3.76 Other (AC:IN_SW-AP_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Software – Application** non identificabili con gli altri valori definiti nel sottoinsieme.

— — — — — • **Software – Other (SW-OH)** • — — — — —

Il **sotto-predicato Software – Other** racchiude tutti gli elementi software che non sono stati racchiusi o classificati nei sotto-predicati precedenti.

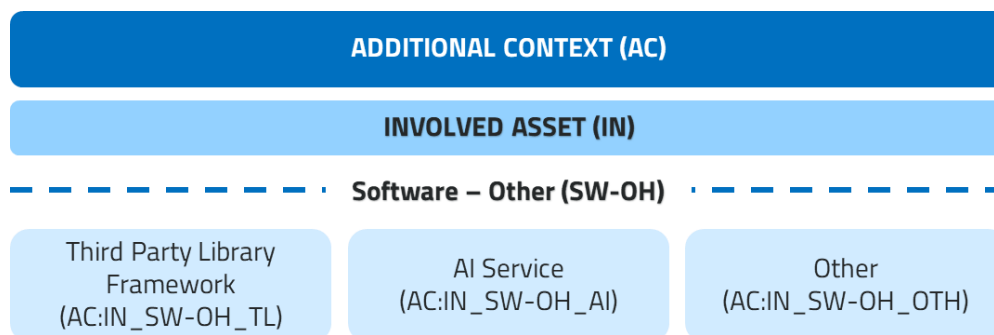


Figura 34: Sotto-predicato "Software - Other" con i relativi valori

3.4.3.77 Third Party Library Framework (AC:IN_SW-OH_TL)

Third Party Library Framework identifica Librerie o Framework di riferimento appartenenti a fonti esterne.

3.4.3.78 AI Service (AC:IN_SW-OH_AI)

AI Service identifica un servizio capace di riprodurre o sostituire l'attività umana mediante decisioni complesse prese in maniera autonoma da parte di computer o macchine. Applicabile in ambito IoT, Industria 4.0, così come in altre aree di applicazione.

3.4.3.79 Other (AC:IN_SW-OH_OTH)

Other racchiude tutti gli asset afferenti al sotto-predicato **Software - Other** non identificabili con gli altri valori definiti nel sottoinsieme.

Information Type (IT)

Il **sotto-predicato Information Type** identifica l'insieme di informazioni/dati che servono a uno specifico processo aziendale o attività dell'organizzazione.

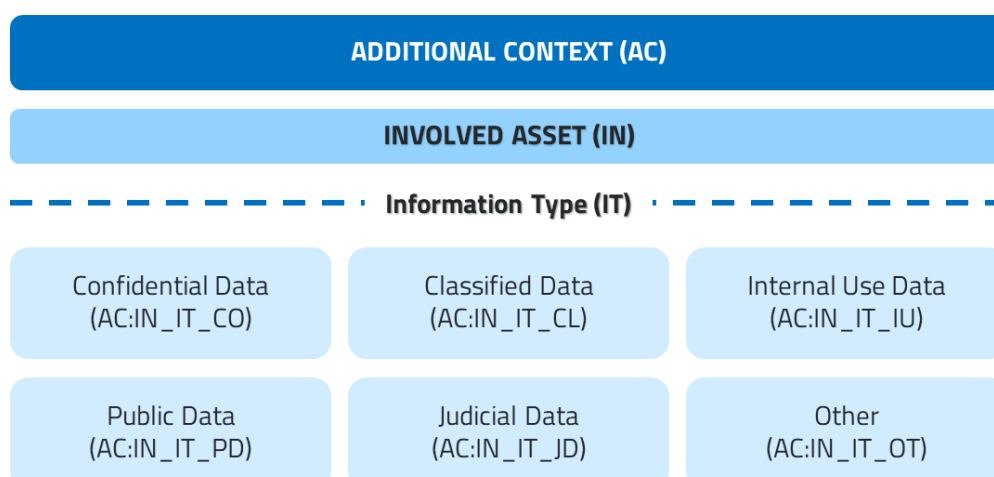


Figura 35: Sotto-predicato "Information Type" con i relativi valori

3.4.3.80 Confidential Data (AC:IN_IT_CO)

Confidential Data identifica dati per cui è necessaria l'autorizzazione per potervi accedere. È possibile concedere l'autorizzazione a specifici dipendenti o fornitori esterni.

3.4.3.81 Classified Data (AC:IN_IT_CL)

Classified Data identifica ogni informazione, atto, attività, documento, cui sia stata attribuita una delle classifiche di segretezza previste dalla legge.

3.4.3.82 Internal Use Data (AC:IN_IT_IU)

Internal Use Data identifica dati il cui accesso è limitato ai soli soggetti interni all'organizzazione.

3.4.3.83 Public Data (AC:IN_IT_PD)

Public Data identifica dati disponibili pubblicamente sia a livello locale che sulla rete internet. Tali dati non richiedono particolari misure di sicurezza e la loro eventuale divulgazione non comporterebbe violazioni delle normative o impatti all'organizzazione.

3.4.3.84 Judicial Data (AC:IN_IT_JD)

Judicial Data identifica dati contenenti informazioni relative ad elementi giudiziari o a provvedimenti in atto.

3.4.3.85 Other (AC:IN_IT_OT)

Other racchiude tutti gli asset afferenti al sotto-predicato **Information Type** non identificabili con gli altri valori definiti nel sottoinsieme.

— — — — — People (PE) — — — — —

Il **sotto-predicato People** identifica gli individui interni o esterni all'organizzazione da cui dipende una funzione essenziale, un servizio essenziale, un asset ICT o una delle sue componenti.

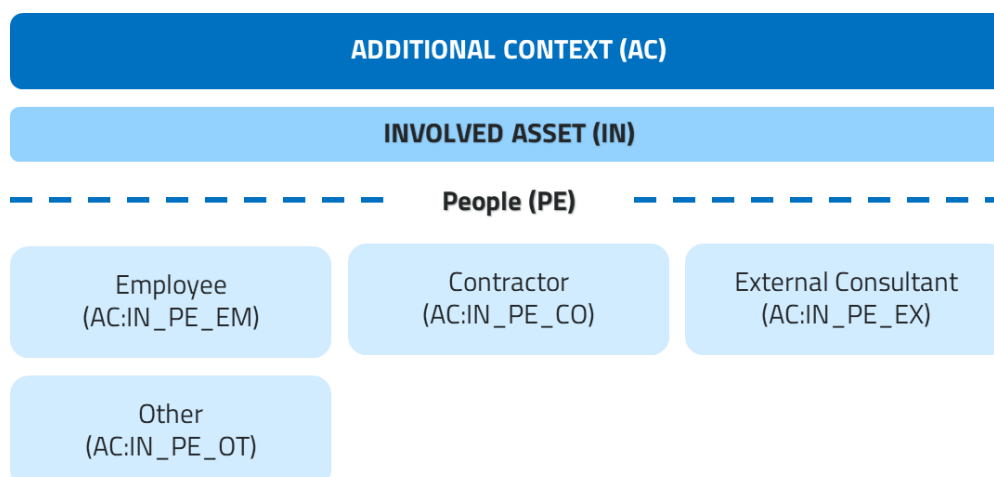


Figura 36: Sotto-predicato "People" con i relativi valori

3.4.3.86 Employee (AC:IN_PE_EM)

Employee identifica persone che lavorano con vincolo di subordinazione per conto di un'azienda o un'organizzazione in forza di un contratto di lavoro, e che percepiscono una remunerazione a fronte del lavoro effettuato.

3.4.3.87 Contractor (AC:IN_PE_CO)

Contractor identifica una organizzazione che fornisce competenze o servizi ad altre organizzazioni per un periodo determinato su base contrattuale.

3.4.3.88 External Consultant (AC:IN_PE_EX)

External Consultant identifica professionisti che forniscono competenze o servizi ad individui o organizzazioni per un periodo determinato su base contrattuale.

3.4.3.89 Other (AC:IN_PE_OT)

Other racchiude tutti gli asset afferenti al sotto-predicato **People** non identificabili con gli altri valori definiti nel sottoinsieme.

Location (LO)

Il **sotto-predicato Location** identifica i locali pertinenti all'operatività di un'organizzazione, come edifici, stanze, uffici e container, insieme ai servizi essenziali e alle utenze fornite da operatori/fornitori esterni, alla fornitura di energia elettrica e acqua.

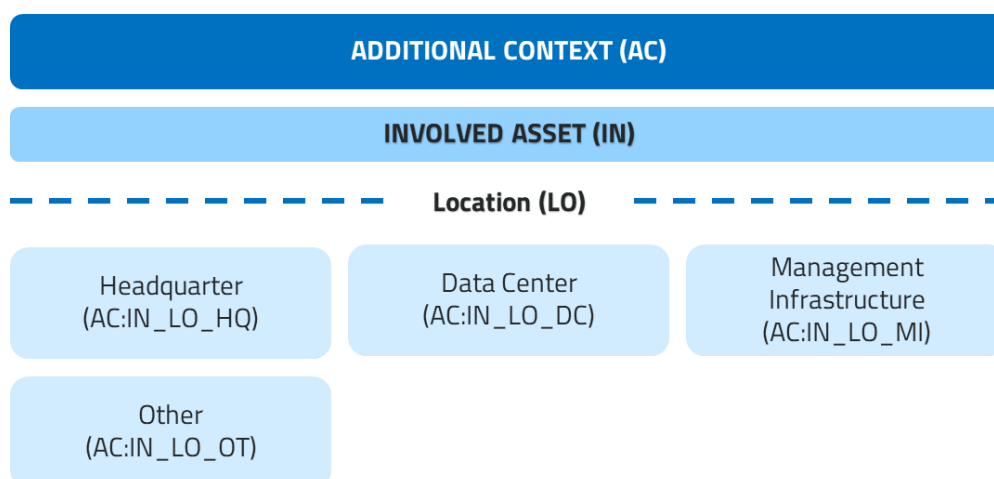


Figura 37: Sotto-predicato "Location" con i relativi valori

3.4.3.90 Headquarter (AC:IN_LO_HQ)

Headquarter identifica la struttura fisica destinata ad accogliere al suo interno personale e/o attività connesse all'operatività dell'organizzazione.

3.4.3.91 Data Center (AC:IN_LO_DC)

Data Center identifica strutture centralizzate che ospitano attrezzature di elaborazione e networking, comunemente note come attrezzature di tecnologia dell'informazione (IT) e infrastrutture di rete.

3.4.3.92 Management Infrastructure (AC:IN_LO_MI)

Management Infrastructure identifica mezzi di trasmissione, tralicci, cabine, stazioni, sistemi di trasporto, pareti, stanze, edifici o qualsiasi oggetto fisico che sia in qualche modo coinvolto nel controllo, nel monitoraggio o nell'analisi dei processi produttivi o nel supporto dell'attività generale.

3.4.3.93 Other (AC:IN_LO_OT)

Other racchiude tutti gli asset afferenti al sotto-predicato **Location** non identificabili con gli altri valori definiti nel sottoinsieme.

----- Other (OT) -----

Il **sotto-predicato Other** racchiude tutti gli elementi Involved Asset che non sono stati racchiusi o classificati nei sotto-predicati precedenti.

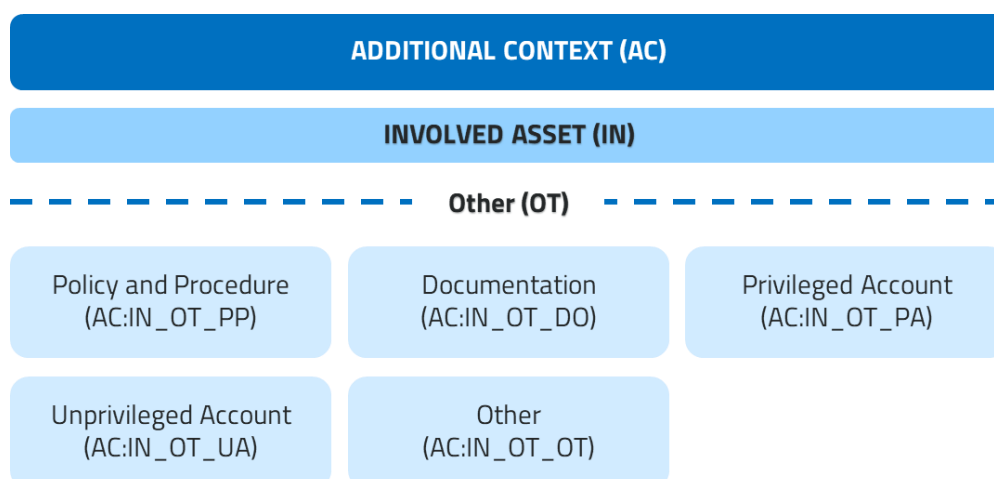


Figura 38: Sotto-predicato "Other" con i relativi valori

3.4.3.94 Policy and Procedure (AC:IN_OT_PP)

Policy and Procedure identifica la documentazione in formato cartaceo o digitale contenente i principi generali dell'organizzazione o di determinati processi o aree aziendali (policy), o documentazione contenente un obiettivo limitato (procedure).

3.4.3.95 Documentation (AC:IN_OT_DO)

Documentation identifica tutti i documenti rilevanti per l'organizzazione e che supportano i processi aziendali come ad esempio manuali operativi.

3.4.3.96 Privileged Account (AC:IN_OT_PA)

Privileged Account identifica un'utenza che ha un ruolo di alto livello in termini di autorizzazione nella gestione di un sistema informatico tale da modificarne le componenti critiche. Ad esempio: la compromissione di un account di amministratore locale o di dominio.

3.4.3.97 Unprivileged Account (AC:IN_OT_UA)

Unprivileged Account identifica un utente con permessi limitati di accesso e di modifica a un sistema o a un'infrastruttura di rete. Un esempio è rappresentato da un attacco che è iniziato dalla compromissione di un account utente.

3.4.3.98 Other (AC:IN_OT_OT)

Other racchiude tutti gli asset afferenti al sotto-predicato **Other** non identificabili con gli altri valori definiti nel sottoinsieme.

3.4.4 Predicato: Outlook (OU)

Il predicato **Outlook** ha l'obiettivo di fornire una prospettiva sull'impatto generato da un evento cyber al momento del rilevamento.

I valori associati a **Outlook** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

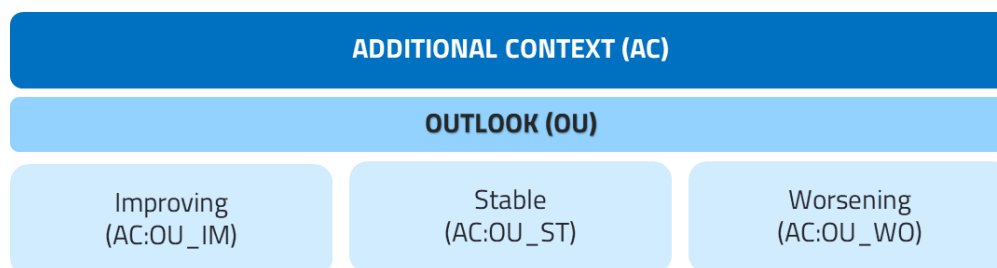


Figura 39: Predicato 'Outlook' con i relativi valori

3.4.4.1 Improving (AC:OU_IM)

Improving identifica un evento cyber in corso per il quale si prevede una riduzione dell'impatto nelle successive sei ore dal momento del rilevamento.

3.4.4.2 Stable (AC:OU_ST)

Stable identifica un evento cyber in corso per il quale si prevede che l'impatto rimanga invariato nelle successive sei ore dal momento del rilevamento.

3.4.4.3 Worsening (AC:OU_WO)

Worsening identifica un evento cyber in corso per il quale si prevede che l'impatto si aggravi nelle successive sei ore dal momento del rilevamento.

3.4.5 Predicato: Physical Security (PH)

Il predicato **Physical Security** identifica gli eventi intenzionali, di natura fisica, con impatto su risorse e servizi informatici. Alcuni esempi possono essere l'accesso fisico non autorizzato a zone riservate da parte di estranei finalizzato al sabotaggio deliberato di una piattaforma operativa o furto di componenti hardware.

I valori associati a **Physical Security** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

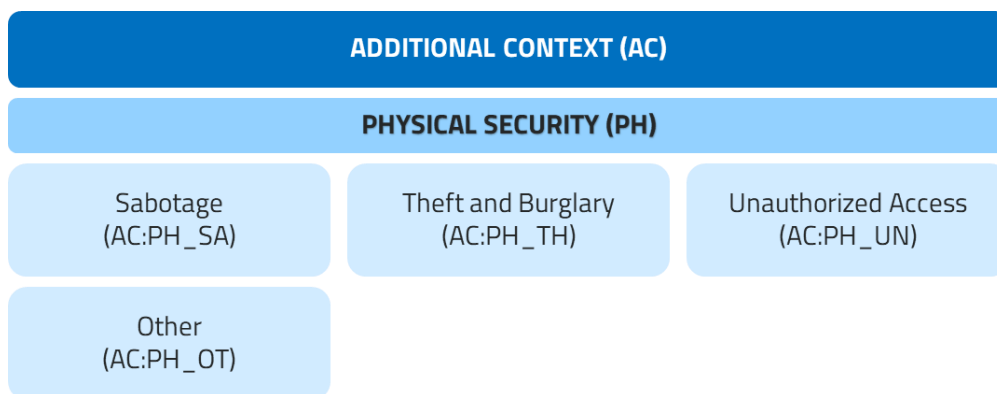


Figura 40: Predicato 'Physical Security' con i relativi valori

3.4.5.1 Sabotage (AC:PH_SA)

Sabotage identifica qualsiasi azione intenzionale volta a danneggiare, distruggere o alterare il funzionamento della risorsa informatica o parti di questa. Queste azioni sono compiute con lo scopo di causare la perdita totale o parziale della disponibilità della risorsa informatica.

3.4.5.2 Theft and Burglary (AC:PH_TH)

Theft and Burglary identifica gli eventi cyber conseguenti al furto di un bene informatico o parti di esso.

3.4.5.3 Unauthorized Access (AC:PH_UN)

Unauthorized Access identifica gli eventi cyber che si verificano quando chiunque ottiene, senza autorizzazione, accesso fisico ad un bene informatico.

3.4.5.4 Other (AC:PH_OT)

Other identifica gli eventi cyber relativi a Physical Security non identificabili con gli altri valori definiti nel sottoinsieme.

3.4.6 Predicato: Vector (VE)

Il predicato **Vector** indica il vettore di attacco utilizzato in un evento cyber. In sicurezza informatica, si definisce vettore d'attacco la modalità con la quale un attore ostile tenta di ottenere l'accesso ad un bene informatico per effettuare attività malevole. Tra i vettori di attacco si annoverano genericamente tattiche, tecniche di attacco e mezzi informatici.

I valori associati a **Vector** identificati dall'Agenzia per la tassonomia degli eventi cyber sono elencati di seguito.

ADDITIONAL CONTEXT (AC)		
VECTOR (VE)		
Abuse of Functionality (AC:VE_AB)	Compromised Domain (AC:VE_CO)	Drive-by Compromise (AC:VE_DR)
E-mail (AC:VE_EM)	Exploiting Vulnerabilities (AC:VE_EV)	External Remote Services (AC:VE_EX)
Hardware Additions (AC:VE_HA)	Social Media (AC:VE_SO)	Supply Chain (AC:VE_SU)
Valid Accounts (AC:VE_VA)	Other (AC:VE_OT)	

Figura 4 1: Predicato 'Vector' con i relativi valori

3.4.6.1 Abuse of Functionality (AC:VE_AB)

Abuse of Functionality identifica gli eventi cyber in cui un attore malevolo sfrutta in modo intenzionale e non convenzionale le funzionalità fornite da un'applicazione o un sito web. In altri termini, può essere descritto come l'abuso di una funzionalità di un'applicazione per ottenere un risultato indesiderato. Ad esempio, nel caso in cui il processo di recupero password non venga implementato nella maniera corretta, un attore malevolo sarà in grado di recuperare informazioni d'interesse (come indirizzo e-mail o nome dell'account).

3.4.6.2 Compromised Domain (AC:VE_CO)

Compromised Domain specifica se l'evento ha interessato un dominio internet lecito che viene utilizzato per veicolare attacchi informatici, quali ad esempio la distribuzione di malware, reindirizzamento della navigazione verso risorse malevole, truffe a danno di soggetti target come il furto di dati personali tramite pagine web illecitamente predisposte.



3.4.6.3 Drive-by Compromise (AC:VE_DR)

Drive-by Compromise identifica gli eventi cyber in cui un utente, tramite la navigazione di un sito web, viene esposto a possibili attacchi, ad esempio tramite lo sfruttamento di vulnerabilità applicative del dispositivo utilizzato o tramite l'uso di codice malevolo, finalizzato alla distribuzione di malware o al furto di token validi per l'accesso applicativo.

3.4.6.4 E-mail (AC:VE_EM)

E-mail identifica gli eventi cyber che utilizzano come vettore d'attacco una casella di posta elettronica (PEC, PEL o PEO).

3.4.6.5 Exploiting Vulnerabilities (AC:VE_EV)

Exploiting Vulnerabilities identifica gli eventi cyber in cui un attaccante tenta o riesce a sfruttare, sia da internet sia da rete interna, vulnerabilità di un bene informatico al fine di accedervi e ottenerne il controllo illecitamente. Questo valore include sia lo sfruttamento di vulnerabilità note, documentate sul database delle CVE (Common Vulnerabilities and Exposures), sia lo sfruttamento di quelle non note, altresì dette vulnerabilità "O-day".

3.4.6.6 External Remote Services (AC:VE_EX)

External Remote Services identifica gli eventi cyber in cui un attore malevolo sfrutta i servizi remoti esposti per accedere e/o persistere all'interno di un bene informatico. Si annoverano in tale categoria tutti quei servizi e meccanismi di accesso che consentono agli utenti di connettersi remotamente alle risorse della rete aziendale. L'abuso di tali servizi può avvenire tramite errate configurazioni, vulnerabilità o l'uso di credenziali valide, per le quali è possibile fare riferimento agli ulteriori e specifici elementi della tassonomia.

3.4.6.7 Hardware Additions (AC:VE_HA)

Hardware Additions identifica gli eventi cyber in cui un attore malevolo utilizza, in modo non autorizzato, dispositivi hardware per eseguire azioni malevole o illecite, ad esempio per accedere ad un bene informatico o intercettare dati sensibili. Un esempio possono essere gli strumenti utilizzati per catturare informazioni, distribuzione malware tramite storage rimovibile o monitorare senza consenso le attività svolte dalla vittima.

3.4.6.8 Social Media (AC:VE_SO)

Social Media identifica gli eventi cyber che utilizzano come vettore d'attacco una piattaforma social per perpetrare attività malevole. Tale valore può riferirsi anche alla pubblicazione di contenuti non autorizzati a seguito di accesso sospetto alla piattaforma social in uso.

3.4.6.9 Supply Chain (AC:VE_SU)

Supply Chain identifica gli eventi cyber che utilizzano come vettore d'attacco prodotti o servizi forniti da terze parti all'interno della catena di approvvigionamento, che presentano vulnerabilità



o che sono stati compromessi prima della distribuzione all'utente finale. Nella fattispecie i criminali informatici possono manomettere la produzione o la distribuzione di un prodotto, hardware o software, installando malware o altri componenti, con lo scopo danneggiare uno o più soggetti, prendendo di mira uno o più elementi della catena di approvvigionamento.

3.4.6.10 Valid Accounts (AC:VE_VA)

Valid Accounts identifica gli eventi cyber che utilizzano come vettore d'attacco un account valido. L'attaccante può sfruttare a proprio vantaggio e illecitamente le autorizzazioni dell'utenza interessata per effettuare attività malevole come ad esempio ottenere privilegi superiori, attivare persistenza, sottrarre illecitamente informazioni o eseguire codice non autorizzato. Questo tipo di evento può coinvolgere sia utenze privilegiate sia non, per le quali specifiche si rimanda ai relativi valori della tassonomia.

3.4.6.11 Other (AC:VE_OT)

Other identifica gli eventi cyber relativi a Vector non identificabili con gli altri valori definiti nel sottoinsieme.

APPENDICE

TASSONOMIA DEGLI EVENTI CYBER

MACROCATEGORIA	PREDICATO	VALORE	CODICE
BASELINE CHARACTERIZATION (BC)	Impact (IM)	Account Compromise	BC:IM_AC
		Application Compromise	BC:IM_AP
		Availability	BC:IM_AV
		Data Exfiltration	BC:IM_DX
		Data Exposure	BC:IM_DE
		Data Manipulation	BC:IM_DM
		No Impact	BC:IM_NO
		System Compromise	BC:IM_SY
		Other	BC:IM_OT
	Root cause (RO)	Human Errors	BC:RO_HU
		Malicious Actions	BC:RO_MA
		Natural Phenomena	BC:RO_NA
		System Failure	BC:RO_SY
		Third Party Failure	BC:RO_TH



MACROCATEGORIA	PREDICATO	VALORE	CODICE
BASELINE CHARACTERIZATION (BC)	Severity (SE)	High	BC:SE_HI
		Medium	BC:SE_ME
		Low	BC:SE_LO
		None	BC:SE_NO
	Victim geography (VG)	Italy	BC:VG_IT
		Africa	BC:VG_AF
		America	BC:VG_AM
		Antarctic	BC:VG_AN
		Asia	BC:VG_AS
		Europe	BC:VG_EU
		Oceania	BC:VG_OC
		Global	BC:VG_GL
THREAT TYPE (TT)	Active scanning (AC)	Credential Scanning	TT:AC_CR
		Network Scanning	TT:AC_NE
		Vulnerability Scanning	TT:AC_VU
		Other	TT:AC_OT
	Availability (AV)	Data Encryption	TT:AV_DA
		DDoS	TT:AV_DD



TLP: CLEAR



MACROCATEGORIA	PREDICATO	VALORE	CODICE
THREAT TYPE (TT)	Availability (AV)	DoS	TT:AV_DO
		Misconfiguration	TT:AV_MI
		Outage	TT:AV_OU
		Other	TT:AV_OT
	Brand abuse (BA)	Account Impersonation	TT:BA_AI
		Cybersquatting	TT:BA_CS
		Name-Logo- Impersonation	TT:BA_NI
		Typosquatting	TT:BA_TS
		Other	TT:BA_OT
	Fraud (FR)	Brand Abuse	TT:FR_BR
		Extortion	TT:FR_EX
		Masquerade	TT:FR_MA
		Resource Misuse	TT:FR_RE
		Spam	TT:FR_SP
		Other	TT:FR_OT



MACROCATEGORIA	PREDICATO	VALORE	CODICE
THREAT TYPE (TT)	Data exposure (DE)	Authentication Data	TT:DE_AU
		Business Data	TT:DE_BU
		Financial Data	TT:DE_FI
		Personal Data	TT:DE_PD
		Other	TT:DE_OT
	Information gathering (IG)	Active Scanning	TT:IG_AC
		Sniffing	TT:IG_SN
		Social Engineering	TT:IG_SO
		Other	TT:IG_OT
	Malicious code (MA)	Backdoor	TT:MA_BA
		Banker	TT:MA_BK
		Bot	TT:MA_BO
		Coin Miner	TT:MA_CO
		Exploit Kit	TT:MA_EX
		Hacking Tool	TT:MA_HA
		Information Stealer	TT:MA_IN



TLP: CLEAR



MACROCATEGORIA	PREDICATO	VALORE	CODICE
THREAT TYPE (TT)	Malicious code (MA)	Loader	TT:MA_LO
		Potentially Unwanted Program	TT:MA_PO
		Ransomware	TT:MA_RA
		Remote Access Tool	TT:MA_RE
		Rootkit	TT:MA_RO
		Trojan	TT:MA_TR
		Virus	TT:MA_VI
		Webshell	TT:MA_WE
		Wiper	TT:MA_WI
		Worm	TT:MA_WO
		Unknown	TT:MA_UN
	Social engineering (SO)	Baiting	TT:SO_BA
		Phishing	TT:SO_PH
		Smishing	TT:SO_SM
		Spear-Phishing	TT:SO_SP
		Vishing	TT:SO_VI



MACROCATEGORIA	PREDICATO	VALORE	CODICE
THREAT TYPE (TT)	Social engineering (SO)	Watering-Hole	TT:SO_WA
		Other	TT:SO_OT
	Vulnerability (VU)	0-Day Vulnerability	TT:VU_0-
		N-Day Vulnerability	TT:VU_N-
		Security Misconfiguration	TT:VU_SE
		Unwanted Exposed Services	TT:VU_UN
		Weak Cryptography	TT:VU_WE
		Proof-of-concept	TT:VU_PC
		Other	TT:VU_OT
THREAT ACTOR (TA)	Adversary motivation (AM)	Destruction	TA:AM_DE
		Espionage	TA:AM_ES
		Ideology	TA:AM_ID
		Influence and Disinformation	TA:AM_IN
		Profit	TA:AM_PR
		Other	TA:AM_OT



TLP: CLEAR



MACROCATEGORIA	PREDICATO	VALORE	CODICE
THREAT ACTOR (TA)	Adversary type (AD)	Criminal	TA:AD_CR
		Hacktivist	TA:AD_HA
		Insider	TA:AD_IN
		Nation State	TA:AD_NA
ADDITIONAL CONTEXT (AC)	Abusive content (AB)	Disturbing Content	AC:AB_DI
		Harmful Speech	AC:AB_HA
		Other	AC:AB_OT
	Asset source geography (AS)	Italy	AC:AS_IT
		Other	AC:AS_OT
	Involved Asset (IN)	Hardware Network Device Router	AC:IN_HW- ND_RT
		Hardware Network Device Switch	AC:IN_HW- ND_SW
		Hardware Network Device Access Point	AC:IN_HW- ND_AP
		Hardware Network Device Other	AC:IN_HW- ND_OTH
		Hardware IoT/IIoT Digital Camera	AC:IN_HW- IT_DC
		Hardware IoT/IIoT Other	AC:IN_HW- IT_OTH



TLP: CLEAR



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Involved Asset (IN)	Hardware Security Appliance Firewall	AC:IN_HW-SA_FW
		Hardware Security Appliance Hardware Security Module	AC:IN_HW-SA_HSM
		Hardware Security Appliance Other	AC:IN_HW-SA_OTH
		Hardware Computer System Server	AC:IN_HW-CS_SR
		Hardware Computer System Printer	AC:IN_HW-CS_PRT
		Hardware Computer System Workstation	AC:IN_HW-CS_WS
		Hardware Computer System Mobile Device	AC:IN_HW-CS_MD
		Hardware Computer System Data Storage	AC:IN_HW-CS_DS
		Hardware Computer System Other	AC:IN_HW-CS_OTH
		Hardware OT Remote Terminal Unit	AC:IN_HW-OT_RTU
		Hardware OT Human Machine Interface	AC:IN_HW-OT_HMI
		Hardware OT Programmable Logic Controller	AC:IN_HW-OT_PLC
		Hardware OT Field Device	AC:IN_HW-OT_FID
		Hardware OT Intelligent Elettronic Device	AC:IN_HW-OT_IED
		Hardware OT Other	AC:IN_HW-OT_OTH
		Hardware Other Satellite System	AC:IN_HW-OH_ST



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Involved Asset (IN)	Hardware Other Unmanned Aerial Vehicle	AC:IN_HW- OH_UAV
		Hardware Other RFID	AC:IN_HW- OH_RFID
		Hardware Other NFC	AC:IN_HW- OH_NFC
		Hardware Other	AC:IN_HW- OH_OTH
		Hardware Virtualization Infrastructure Other	AC:IN_HW- VI_OTH
		Software Security System Firewall OS	AC:IN_SW- SS_FO
		Software Security System Antivirus	AC:IN_SW- SS_AV
		Software Security System Intrusion Detection System	AC:IN_SW- SS_IDS
		Software Security System Intrusion Prevention System	AC:IN_SW- SS_IPS
		Software Security System Antispam	AC:IN_SW- SS_AS
		Software Security System Security Information and Event Management	AC:IN_SW- SS_SIEM
		Software Security System Proxy	AC:IN_SW- SS_PX
		Software Security System Certification Authority	AC:IN_SW- SS_CA
		Software Security System Virtual Private Network	AC:IN_SW- SS_VP
		Software Security System Access Management	AC:IN_SW- SS_AM
		Software Security System Web Application Firewall	AC:IN_SW- SS_WAF



TLP: CLEAR



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Involved Asset (IN)	Software Security System Other	AC:IN_SW-SS_OTH
		Software Data Management Database	AC:IN_SW-DM_DB
		Software Data Management Blockchain	AC:IN_SW-DM_BC
		Software Data Management Data Lake	AC:IN_SW-DM_DL
		Software Data Management Backup	AC:IN_SW-DM_BK
		Software Data Management Data Vault	AC:IN_SW-DM_DV
		Software Data Management Other	AC:IN_SW-DM_OTH
		Software OT Supervisory Control And Data Acquisition	AC:IN_SW-OT_SCADA
		Software OT Manufacturing Operations Management	AC:IN_SW-OT_MOM
		Software OT Distributed Control System	AC:IN_SW-OT_DCS
		Software OT Building Automation System	AC:IN_SW-OT_BAS
		Software OT Physical Access Control System	AC:IN_SW-OT_PACS
		Software OT Communication Protocol	AC:IN_SW-OT_CP
		Software OT Front End Processor	AC:IN_SW-OT_FEP
		Software OT Historian	AC:IN_SW-OT_HS
		Software OT Manufacturing Execution System	AC:IN_SW-OT_MES



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Involved Asset (IN)	Software OT Other	AC:IN_SW-OT_OTH
		Software Operating System Firmware	AC:IN_SW-OS_FW
		Software Operating System Windows	AC:IN_SW-OS_WIN
		Software Operating System Linux	AC:IN_SW-OS_LX
		Software Operating System MacOS	AC:IN_SW-OS_MAC
		Software Operating System iOS	AC:IN_SW-OS_IOS
		Software Operating System Android	AC:IN_SW-OS_AND
		Software Operating System Other	AC:IN_SW-OS_OTH
		Software Virtualization Software Hypervisor	AC:IN_SW-VS_HY
		Software Virtualization Software Other	AC:IN_SW-VS_OTH
		Software IoT/IIoT Other	AC:IN_SW-IT_OTH
		Software Application Web HTTP HTTPS Server	AC:IN_SW-AP_WO
		Software Application Mail ServerPop SMTP IMAP	AC:IN_SW-AP_ML
		Software Application Naming Server DNS	AC:IN_SW-AP_DNS
		Software Application S FTP Server Application	AC:IN_SW-AP_FTP
		Software Application Remote S Shell Server Application	AC:IN_SW-AP_SSH



TLP: CLEAR



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Involved Asset (IN)	Software Application NTP Server Application	AC:IN_SW- AP_NTP
		Software Application Chat IRC Server Application	AC:IN_SW- AP_IRC
		Software Application RPC Server Application	AC:IN_SW- AP_RPC
		Software Application LDAP Server Application	AC:IN_SW- AP_LDAP
		Software Application RTSP Server Application	AC:IN_SW- AP_RTSP
		Software Application Other	AC:IN_SW- AP_OTH
		Software Other Third Party Library Framework	AC:IN_SW- OH_TL
		Software Other AI Service	AC:IN_SW- OH_AI
		Software Other	AC:IN_SW- OH_OTH
		Information Type Confidential Data	AC:IN_IT_CO
		Information Type Classified Data	AC:IN_IT_CL
		Information Type Internal Use Data	AC:IN_IT_IU
		Information Type Public Data	AC:IN_IT_PD
		Information Type Judicial Data	AC:IN_IT_JD
		Information Type Other	AC:IN_IT_OT
		People Employee	AC:IN_PE_E M



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Involved Asset (IN)	People Contractor	AC:IN_PE_C O
		People External Consultant	AC:IN_PE_E X
		People Other	AC:IN_PE_O T
		Location Headquarter	AC:IN_LO_H Q
		Location Data Center	AC:IN_LO_D C
		Location Management Infrastructure	AC:IN_LO_M I
		Location Other	AC:IN_LO_O T
		Other Policy and Procedure	AC:IN_OT_P P
		Other Documentation	AC:IN_OT_D O
		Other Privileged Account	AC:IN_OT_P A
		Other Unprivileged Account	AC:IN_OT_U A
		Other	AC:IN_OT_O T
	Outlook (OU)	Improving	AC:OU_IM
		Stable	AC:OU_ST
		Worsening	AC:OU_WO



MACROCATEGORIA	PREDICATO	VALORE	CODICE
ADDITIONAL CONTEXT (AC)	Physical security (PH)	Sabotage	AC:PH_SA
		Theft and Burglary	AC:PH_TH
		Unauthorized Access	AC:PH_UN
		Other	AC:PH_OT
	Vector (VE)	Abuse of Functionality	AC:VE_AB
		Compromised Domain	AC:VE_CO
		Drive-by Compromise	AC:VE_DR
		E-mail	AC:VE_EM
		Exploiting Vulnerabilities	AC:VE_EV
		External Remote Services	AC:VE_EX
		Hardware Additions	AC:VE_HA
		Social Media	AC:VE_SO
		Supply Chain	AC:VE_SU
		Valid Accounts	AC:VE_VA
		Other	AC:VE_OT

Tabella 1: Tassonomia degli eventi cyber

